



Universität
Bremen

Bachelorarbeit

im Studiengang Informatik
Fachbereich 3 - Mathematik und Informatik
Digital Media Lab

**Threat Modeling durch KI:
Untersuchung der Wahrnehmung von Entwicklern**

von

Saskia Jürgens

Erstprüfer:	Dr. Mehrdad Bahrini
Zweitprüfer:	Prof. Dr. Ute Bormann
Betreuer:	Dr. Mehrdad Bahrini

Matrikelnummer:	614356
E-Mail-Adresse:	saskia.key@web.de
Eingereicht am:	Februar 26, 2026

Danksagungen

Ich möchte mich an dieser Stelle bei allen Probanden bedanken, die sich an der Studie, die der vorliegenden Arbeit zugrunde liegt, beteiligt haben. Danken möchte ich auch Dr. Mehrdad Bahrini für die Betreuung der Arbeit.

**Eigenständigkeits- und Einverständniserklärung zur Überprüfung mit Plagiatsoftware
sowie die Erklärung zur Veröffentlichung bei Bachelor- und Masterarbeiten****Declarations of Authorship and Consent for Checking with Plagiarism Software and the
Declaration of Publication for Bachelor's and Master's Thesis**

Studierenden-Angaben / Student Information:

Matrikelnr./ Student ID	614356
Nachname / Surname	Jürgens
Vorname / First Name	Saskia

Titel der Arbeit / Title of Thesis

Threat Modeling durch KI: Untersuchung der Wahrnehmung von Entwicklern**A) Eigenständigkeitserklärung / Declaration of Authorship**

Ich versichere, dass ich die vorliegende Arbeit selbstständig verfasst und keine anderen als die angegebenen Quellen und Hilfsmittel verwendet habe. Alle Teile meiner Arbeit, die wortwörtlich oder dem Sinn nach anderen Werken entnommen sind, wurden unter Angabe der Quelle kenntlich gemacht. Gleiches gilt auch für Zeichnungen, Skizzen, bildliche Darstellungen sowie für Quellen aus dem Internet, dazu zählen auch KI-basierte Anwendungen oder Werkzeuge. Die Arbeit wurde in gleicher oder ähnlicher Form noch nicht als Prüfungsleistung eingereicht.

I hereby affirm that I have written the present work independently and have used no sources or aids other than those indicated. All parts of my work that have been taken from other works, either verbatim or in terms of meaning, have been marked as such, indicating the source. The same applies to drawings, sketches, pictorial representations and sources from the Internet, including AI-based applications or tools. The work has not yet been submitted in the same or a similar form as a final examination paper.

- ☒ Ich habe KI-basierte Anwendungen und/oder Werkzeuge genutzt und diese im Anhang "Nutzung KI basierte Anwendungen" dokumentiert.

I have used AI-based applications and/or tools and documented them in the appendix "Use of AI-based applications".

B) Erklärung zur Veröffentlichung von Bachelor- oder Masterarbeiten
Declaration regarding the publication of bachelor's or master's thesis

Die Abschlussarbeit wird zwei Jahre nach Studienabschluss dem Archiv der Universität Bremen zur dauerhaften Archivierung angeboten. Archiviert werden:

Two years after graduation, the thesis is offered to the archive of the University of Bremen for permanent archiving. The following are archived:

- 1) Masterarbeiten mit lokalem oder regionalem Bezug sowie pro Studienfach und Studienjahr 10 % aller Masterarbeiten
Master's theses with a local or regional focus, as well as per subject and academic year 10% of all Master's thesis
- 2) Bachelorarbeiten des jeweils ersten und letzten Bachelorabschlusses pro Studienfach und Jahr.
Bachelor's thesis for the first and last bachelor's degrees per subject and year.

☒ Ich bin damit einverstanden, dass meine Abschlussarbeit im Universitätsarchiv für wissenschaftliche Zwecke von Dritten eingesehen werden darf.
I agree that my thesis may be viewed by third parties in the university archive for academic purposes.

☒ Ich bin damit einverstanden, dass meine Abschlussarbeit nach 30 Jahren (gem. §7 Abs. 2 BremArchivG) im Universitätsarchiv für wissenschaftliche Zwecke von Dritten eingesehen werden darf.
I agree that my thesis may be viewed by third parties for academic purposes in the university archive after 30 years (in accordance with §7 para. 2 BremArchivG).

☐ Ich bin **nicht** damit einverstanden, dass meine Abschlussarbeit im Universitätsarchiv für wissenschaftliche Zwecke von Dritten eingesehen werden darf.
I do not consent to my thesis being made available in the university archive for third parties to view for academic purposes.

C) Einverständniserklärung zur elektronischen Überprüfung der Arbeit auf Plagiate
Declaration of consent for electronic checking of the work for plagiarism

Eingereichte Arbeiten können nach § 18 des Allgemeinen Teil der Bachelor- bzw. der Masterprüfungsordnungen der Universität Bremen mit qualifizierter Software auf Plagiatvorwürfe untersucht werden.

Zum Zweck der Überprüfung auf Plagiate erfolgt das Hochladen auf den Server der von der Universität Bremen aktuell genutzten Plagiatsoftware.

Submitted papers can be checked for plagiarism using qualified software in accordance with § 18 of the General Section of the Bachelor's or Master's Degree Examination Regulations of the University of Bremen. For the purpose of checking for plagiarism, the upload to the server is done using the plagiarism software currently used by the University of Bremen.

- ☒ Ich bin damit einverstanden, dass die von mir vorgelegte und verfasste Arbeit zum oben genannten Zweck dauerhaft auf dem externen Server der aktuell von der Universität Bremen genutzten Plagiatsoftware, in einer institutionseigenen Bibliothek (Zugriff nur durch die Universität Bremen), gespeichert wird.

I agree that the work I have submitted and written will be stored permanently on the external server of the plagiarism software currently used by the University of Bremen, in a library belonging to the institution (accessed only by the University of Bremen), for the above-mentioned purpose.

- ☐ Ich bin **nicht** damit einverstanden, dass die von mir vorgelegte und verfasste Arbeit zum o.g. Zweck dauerhaft auf dem externen Server der aktuell von der Universität Bremen genutzten Plagiatsoftware, in einer institutionseigenen Bibliothek (Zugriff nur durch die Universität Bremen), gespeichert wird.

I do not consent to the work I submitted and wrote being permanently stored on the external server of the plagiarism software currently used by the University of Bremen, in a library belonging to the institution (accessed only by the University of Bremen), for the above-mentioned purpose.

Das Einverständnis der dauerhaften Speicherung des Textes ist freiwillig. Die Einwilligung kann jederzeit durch Erklärung gegenüber der Universität Bremen, mit Wirkung für die Zukunft, widerrufen werden. Weitere Informationen zur Überprüfung von schriftlichen Arbeiten durch die Plagiatsoftware sind im Nutzungs- und Datenschutzkonzept enthalten. Diese finden Sie auf der Internetseite der Universität Bremen.

Consent to the permanent storage of the text is voluntary. Consent can be withdrawn at any time by making a declaration to this effect to the University of Bremen, with effect for the future. Further information on the checking of written work using plagiarism software can be found in the data protection and usage concept. This can be found on the University of Bremen website.

Mit meiner Unterschrift versichere ich, dass ich die obenstehenden Erklärungen gelesen und verstanden habe und bestätige die Richtigkeit der gemachten Angaben.

With my signature, I confirm that I have read and understood the above explanations and confirm the accuracy of the information provided.

Datum / Date

Unterschrift/ Signature

Zusammenfassung

Die zunehmende Komplexität von KI Moderne IT-Systeme, insbesondere cloud- und IoT-basierte Architekturen, stellt hohe Anforderungen an die frühzeitige Identifikation und Bewertung von Sicherheitsrisiken. Threat Modeling gilt zwar als bewährter Ansatz zur präventiven Sicherheitsanalyse, ist in der praktischen Anwendung jedoch häufig zeitaufwendig, stark wissensabhängig und fehleranfällig. Vor diesem Hintergrund untersucht diese Arbeit, inwiefern große Sprachmodelle (LLMs) wie ChatGPT den Threat-Modeling-Prozess auf Basis von Data-Flow-Diagrammen (DFDs) sinnvoll unterstützen können.

Ziel dieser Arbeit ist die Analyse der Wahrnehmung von Softwareentwickler:innen und IT-nahen Fachpersonen gegenüber einem KI-gestützten Threat-Modeling-Assistenten. Im Fokus stehen dabei die Nachvollziehbarkeit der KI-generierten Ergebnisse, das Vertrauen in die Analyse und der wahrgenommene Nutzen eines interaktiven, dialogbasierten Ansatzes. Auf dieser Grundlage wurden mehrere Hypothesen formuliert.

Die Arbeit ist durch aktuelle Forschungsergebnisse motiviert, die LLMs ein hohes Potenzial zur Unterstützung sicherheitsrelevanter Analyseprozesse zuschreiben. Gleichzeitig wird jedoch auf zentrale Herausforderungen wie fehlendes Kontextverständnis, eingeschränkte Erklärbarkeit und die Gefahr der unkritischen Übernahme von KI-Vorschlägen hingewiesen. Bislang fehlt laut meiner Recherchen insbesondere eine nutzerzentrierte Betrachtung der praktischen Interaktion mit solchen Systemen im Kontext des Threat Modeling.

Die Arbeit basiert methodisch auf einem mehrstufigen, qualitativen Forschungsdesign. In einem ersten Schritt wurde in einem Experten-Workshop ein konzeptioneller Ansatz für ein KI-gestütztes Threat-Modeling-Interface erarbeitet. Auf Basis der dort gewonnenen Erkenntnisse wurde ein interaktiver Prototyp des Interfaces entwickelt, der DFDs im JSON-Format verarbeitet und eine STRIDE-basierte Bedrohungsanalyse unterstützt. Dieser Prototyp wurde anschließend in einer Nutzerstudie mit 13 Teilnehmenden evaluiert. Die Teilnehmenden bearbeiteten drei aufeinander aufbauende Szenarien: eine automatisierte Analyse eines gegebenen DFDs, eine iterative

VI

Analyse mit zusätzlichem Kontext sowie eine explorative Untersuchung potenzieller Angriffe aus der Angreiferperspektive („Think like a hacker“). Die Datenerhebung erfolgte mittels Beobachtung, Screen- und Audioaufzeichnung sowie eines standardisierten Fragebogens, der über ein Google-Formular ausgefüllt wurde.

Die Ergebnisse dieser Arbeit zeigen, dass der KI-Assistent grundsätzlich dazu in der Lage ist, relevante Bedrohungskategorien zu identifizieren und strukturierte Analysen bereitzustellen. Gleichzeitig wurde deutlich, dass die Verständlichkeit und Nachvollziehbarkeit der Ergebnisse stark von der Qualität und Kontexttiefe der Eingaben abhängen. Durch iterative Interaktion und zusätzliche Kontextinformationen konnten differenziertere Analysen erstellt werden, die als hilfreicher wahrgenommen wurden. In Bezug auf Vertrauen zeigte sich, dass eine transparente Kommunikation von Unsicherheiten sowie erklärende Ausgaben eine zentrale Rolle spielen. Insgesamt verdeutlichen die Ergebnisse, dass KI-gestütztes Threat Modeling als unterstützendes Assistenzsystem wahrgenommen wird, eine vollautonome Nutzung jedoch kritisch gesehen wird und weiterhin menschliche Kontrolle und fachliche Reflexion erfordert.

<i>Inhaltsverzeichnis</i>	III
---------------------------	-----

Inhaltsverzeichnis

Abbildungsverzeichnis	V
------------------------------	----------

Abkürzungsverzeichnis	VII
------------------------------	------------

1. Einleitung	1
1.1. Hintergrund und Motivation	1
1.2. Zielsetzungen und Forschungsfragen	4
1.3. Aufbau der Arbeit	5
2. Verwandte Arbeiten	7
2.1. Automatisiertes Threat Modeling mit LLMs	7
2.2. Klassische und halbautomatisierte Threat-Modeling-Ansätze	10
2.3. Menschliche Einflussfaktoren im Threat Modeling	11
2.4. Hybridmodelle: Kombination von DFDs und LLMs	12
2.5. Zusammenfassung der Verwandete Arbeiten	13
3. Methodik	14
3.1. Workshop	14
3.1.1. Teilnehmer:innen	14
3.1.2. Materialien	15
3.1.3. Durchführung	16
3.1.4. Auswertung	16
3.1.5. Prototyp	17
3.2. Prototyp Useability Test	25
3.2.1. Teilnehmer:innen	25
3.2.2. Materialien	25
3.2.3. Durchführung	25
3.2.4. Auswertung	26
3.3. Nutzerstudie	26
3.3.1. Teilnehmer:innen	26
3.3.2. Hypothesen und Untersuchungsfokus	27
3.3.3. Materialien	27
3.3.4. Durchführung	29
3.3.4.1. Szenario 1: Automatisiertes Threat Modeling auf Basis eines DFD	29

IV

3.3.4.2.	Szenario 2: Kontextanreicherung und iterative Analyse	30
3.3.4.3.	Szenario 3: „Think like a hacker“ – Angreiferperspektive	30
4.	Nutzerstudie Ergebnisse	32
4.1.	Teilnehmer:innen Hintergrund	32
4.1.1.	Szenario 1: Analyse eines gegebenen DFDs	33
4.1.2.	Szenario 2: Iterative Verbesserung durch zusätzlichen Kontext	35
4.1.3.	Szenario 3: „Think like a hacker“ – Angriffsdenken und Vertrauensbewertung	38
4.1.4.	Zusammenfassende Ergebnisdarstellung	40
5.	Diskussion	41
5.1.	Verständlichkeit und Transparenz einer KI (H1)	41
5.2.	Vertrauen in den KI-Assistenten (H2)	42
5.3.	Interaktivität und iterative Nutzung (H3)	42
5.4.	Zusammenfassende Einordnung	43
5.5.	Limitation der Studie	44
6.	Fazit und künftige Arbeiten	45
	Literatur	49
A.	KI-basierte Anwendungen	51

Abbildungsverzeichnis

1.	DFD Beispiel [Horst, 2025]	2
2.	Interface Screenshot	17
3.	Interface Screenshot - KI Vorschläge	19
4.	Interface Screenshot - JSON Upload	20
5.	Prototyp Screenshot - Wissensstand Regler	21
6.	Prototyp Screenshot - Chat	22
7.	Prototyp Screenshot - Sessions	23
8.	Szenario 1 – Verständlichkeit	34
9.	Szenario 1 – Vertrauen	34
10.	Szenario 1 – Interaktivität	34
11.	Szenario 2 – Verständlichkeit	36
12.	Szenario 2 – Vertrauen	36
13.	Szenario 2 – Interaktivität	36
14.	Szenario 3 – Verständlichkeit	38
15.	Szenario 3 – Vertrauen	38
16.	Szenario 3 – Interaktivität	38

Abkürzungsverzeichnis

DFD	Data Flow Diagram / Datenflussdiagramm
LLM	Large Language Model / Großes Sprachmodell
KI	Künstliche Intelligenz
IoT	Internet of Things
DSGVO	Datenschutz-Grundverordnung
ISO	International Organization for Standardization

1. Einleitung

1.1. Hintergrund und Motivation

Die zunehmende Verbreitung von KI führt zu zahlreichen grundlegende Veränderungen in der Arbeitswelt. Ob in der industriellen Produktion, im Bildungsbereich oder in der öffentlichen Verwaltung, KI-Systeme übernehmen immer mehr Aufgaben, die früher ausschließlich von Menschen ausgeführt wurden [Sahoo et al., 2024]. Diese Entwicklung wird besonders sichtbar, in den vernetzten Systemen, die Maschinen, Sensoren, Datenplattform und Software miteinander verknüpfen [a) Chiş et al., 2024]. Einerseits führt die stetig steigende Nutzung solcher Technologien zu beträchtlichem Effizienzgewinn und neuen Innovationspotenzialen [Wu et al., 2024].

Andererseits bringen sie aber auch größere Herausforderungen in Bezug auf die IT-Sicherheit mit sich. Vor allem in sicherheitskritischen Infrastrukturen und bei sensiblen Datenverarbeitungsprozessen stellen diese Entwicklungen große Herausforderungen dar. Die zunehmende Komplexität solcher Systeme erschwert deren Übersicht und Absicherung erheblich [Sharma and Bhushan, 2026]. In Zeiten fortschreitender Digitalisierung und Vernetzung wird IT-Sicherheit dadurch zu einem strategischen Erfolgsfaktor für Unternehmen, insbesondere bei komplexen cloud- oder IoT-basierten (vernetzte physische Geräte mit Sensoren und Software) Anwendungen [Sonnenburg et al., 2025]. Die klassische Herangehensweise, Software-Sicherheit nachträglich zu testen oder erst nach Auftreten von Vorfällen darauf zu reagieren, reicht nicht mehr aus. Deshalb wächst die Relevanz von präventiven Maßnahmen wie das Testen von Sicherheitslücken bereits zu Beginn in der Planungs- und Entwicklungsphase eines IT-Systems. In einem solchen Verfahren ist das sogenannte Threat Modeling eine bewährte Mittel [Xiong and Lagerström, 2019].

Was genau ist Threat Modeling? Threat Modeling ist ein strukturierter Prozess, mit dem potenzielle Sicherheitsrisiken in IT-Systemen frühzeitig erkannt und bewertet werden. Ziel ist es, systematisch zu fragen, wie ein System angegriffen oder missbraucht werden könnte, noch bevor es vollständig entwickelt oder in Betrieb genommen wird, um und geeignete Gegenmaßnahmen zu planen, statt Sicherheitslücken erst nachträglich zu

beheben. Besonders in der Softwareentwicklung verwenden Sicherheits-, Softwareexpert:innen oder Entwicklerteams häufig Threat Modeling, das als wichtiger Bestandteil eines sicherheitsbewussten Entwicklungsprozesses gilt [Shostack, 2014].

Unternehmen und Organisationen weltweit greifen auf verschiedene Methoden und Frameworks zurück, wie beispielsweise STRIDE, um sicherzustellen, dass ihre Systeme gegen bekannte und unbekannte Bedrohungen gesichert sind. Ein essentielles Werkzeug in diesem Prozess sind Data Flow Diagrams (DFDs) [Souppaya and Scarfone, 2016].

Was ist ein Data Flow Diagram (DFD)?

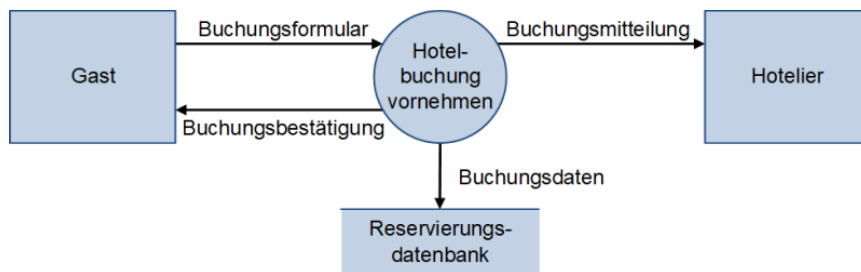


Abbildung 1: DFD Beispiel [Horst, 2025]

Abbildung 1 zeigt ein exemplarisches Data-Flow-Diagramm für einen einfachen Hotelbuchungsprozess. Dargestellt sind die beteiligten externen Akteure, Gast und Hotelier, der zentrale Prozess der Hotelbuchung sowie die Reservierungsdatenbank. Die Pfeile verdeutlichen die einzelnen Datenflüsse, wie etwa das Buchungsformular, die Buchungsbestätigung und die Speicherung der Buchungsdaten.

Ein DFD ist Modell zur Darstellung von Datenflüssen innerhalb eines Systems, wie z.B. bei IoT. Es veranschaulicht, wer am Systems beteiligt ist, welche internen Abläufe stattfinden und wie Informationen zwischen den einzelnen Komponenten übertragen werden. Das Ergebnis ist ein übersichtliches Bild der Systemsarchitektur, das die Basis für gezielte Sicherheitsanalysen bildet [DeMarco, 2011].

Obwohl Threat Modeling von großer Bedeutung für die IT-Sicherheit ist, erweist sich der Prozess in der Praxis oft als zeitaufwendig, fehleranfällig und stark abhängig vom domänenspezifischen Wissen einzelner Per-

sonen [Scandariato et al., 2015]. Neue KI-Technologien, vor allem Large Language Models (LLMs/ KI-Modell) wie ChatGPT¹, könnten hier aushelfen, beispielsweise durch automatisch unterstützte Analyse von DFDs oder durch die Entwicklung möglicher Bedrohungsszenarien und dem Ausgeben von Vorschlägen für Gegenmaßnahmen [Mbaka and Tuma, 2024].

Denn moderne IT-Architekturen bestehen aus einer Vielzahl an Schnittstellen, Diensten und Technologien, wodurch selbst erfahrene Entwickler:innen leicht den Überblick verlieren. Sie könnten IT-Sicherheitsexpert:innen als Überprüfungswerkzeug zum Identifizieren von übersehenen Bedrohungen in der eigenen Analyse dienen, oder das LLM identifiziert die grundlegenden Sicherheitslücken zeiteffizienter und Expert:innen überprüfen dessen Output und knüpfen daran an, um die komplexeren und kontextspezifischeren Sicherheitsbedrohungen zu finden, die das LLM nicht finden konnte. Denn die Fähigkeit der LLMs, kontextuelle Informationen zu verarbeiten und komplexe Texte zu generieren, macht sie zu potenziell wertvollen Helfern, nicht nur für Privatanutzer:innen, sondern auch für IT-Sicherheitsexpert:innen. Vertrauen, Transparenz und Benutzerfreundlichkeit sind entscheidende Faktoren für einen erfolgreichen Einsatz in der Praxis eines solchen Systems [Tuma and Mbaka, 2022].

LLMs werden bereits heute in zahlreichen Anwendungsfeldern genutzt, von der automatisierten Textgenerierung über die Programmierhilfe bis hin zur juristischen oder medizinischen Unterstützung. Auch erste Studien zeigen vielversprechende Ansätze, weisen aber auch auf Herausforderungen hin, z.B. das nicht existente Fehler erkannt werden, Begründungen unklar sind oder fehlender Kontext bei komplexen Systemen zu einer unausreichenden Analyse führen [Wu et al., 2024]. Vor diesem Hintergrund untersucht die vorliegende Arbeit, inwiefern LLMs wie ChatGPT den Prozess des Threat Modeling mit Hilfe von DFDs unterstützen können. Dabei wird auch geprüft, wie eine Zusammenarbeit zwischen Mensch und Maschine gestaltet sein sollte, um zuverlässig, verständlich und nützlich zu sein.

Warum ist dieses Thema also so relevant? Zum einen steht die Frage im Raum, wie sich der klassische Threat-Modeling-Prozess durch moderne KI-Tools verbessern lässt, sei es durch Zeitersparnis, durch breitere Abdeckung

¹<https://openai.com>

möglicher Bedrohungen oder durch eine Vereinfachung der Sicherheitsanalyse für nicht-expertische Nutzer:innen. Zum anderen muss geklärt werden, wie vertrauenswürdig die Ergebnisse der KI-Systeme tatsächlich sind: Wie nachvollziehbar sind die Vorschläge? Wo sind ihre Grenzen? Und wie gelingt die Interaktion zwischen Mensch und Maschine in einem sicherheitskritischen Kontext? Die vorliegende Arbeit beschäftigt sich genau mit diesen Fragen. Sie nimmt eine interdisziplinäre Perspektive ein, indem sie sowohl die technischen Möglichkeiten als auch die praktischen Herausforderungen betrachtet. Dabei geht es nicht nur um die Frage, ob ein LLM wie ChatGPT Bedrohungen erkennen kann, sondern auch darum, wie dieser Prozess gestaltet sein muss, damit er verständlich, nutzbar und vertrauenswürdig ist. Ein besonderer Fokus liegt auf der Zusammenarbeit verschiedener Fachgruppen. Denn Softwareentwicklung, IT-Sicherheit und KI-Technologie sind drei Disziplinen mit unterschiedlichen Perspektiven, Anforderungen und Sprachen. Ein System, das in der einen Domäne als nützlich erachtet wird, kann in der anderen möglicherweise als unbrauchbar angesehen werden, sei es aufgrund von Kontrollmangel oder unzureichenden Anpassungsmöglichkeiten. Deshalb wurde in dieser Arbeit, nach Rücksprache mit Experten aus allen drei Domänen, ein Prototyp entwickelt, der sofort getestet und bewertet wurde.

Zusammengefasst wird analysiert, wie KI-Systeme in sicherheitsrelevante Entscheidungsprozesse integrieren werden können, ohne dass der Mensch die Kontrolle verliert. Ebenso wie Risiken kommuniziert werden und unter welchen Bedingungen ein solches System als unterstützend und nicht als bedrohlich empfunden wird. Die Arbeit versucht, den Sicherheitsprozess darauf zu überprüfen, ob LLMs in der Softwareentwicklung effizientere, sicherere und zugänglichere Lösungen bieten. Sie will dabei neueste technologische Entwicklungen mit einem klaren gesellschaftlichen Nutzen verbinden und leistet dabei einen Beitrag zur verantwortungsvollen Integration von KI in sicherheitskritischen Prozessen.

1.2. Zielsetzungen und Forschungsfragen

Das Ziel dieser Arbeit ist es zu verstehen, wie Expert:innen für große Sprachmodelle, Softwareentwickler:innen und IT-Sicherheitsexpert:innen mit ei-

nem System zur Bedrohungsmodellierung arbeiten, das auf einem LLM basiert.

Im Mittelpunkt steht die Frage, wie man sowohl den Prozess als auch die Ergebnisse der Bedrohungsanalyse verbessern kann und welche Bedingungen erfüllt sein müssen, damit eine vertrauenswürdige und nachvollziehbare Mensch-Maschine-Interaktion gelingt. Es soll ein interaktives System entwickelt und getestet werden, das auf LLMs basiert, welches DFDs nutzt, um bei der Bedrohungsmodellierung zu unterstützen. Dabei wird insbesondere untersucht, inwiefern die Verständlichkeit und Nachvollziehbarkeit der KI-generierten Ergebnisse von der Qualität, Struktur und Kontexttiefe der bereitgestellten Eingaben abhängt. Außerdem wird genauer angeschaut, wie die verschiedenen Fachgruppen diesen Prozess wahrnehmen, welche Erwartungen sie haben und unter welchen Umständen sie ein solches System als hilfreich, vertrauenswürdig und verlässlich einstufen.

Ein weiterer Fokus liegt auf der Gestaltung der Interaktion zwischen Mensch und System. Es wird untersucht, inwiefern ein dialogbasierter, iterativer Analyseprozess, bei dem das System Rückfragen zu unvollständigen oder unklaren Eingaben stellt, gegenüber einer einmaligen, statischen Analyse als nutzerfreundlicher und unterstützender wahrgenommen wird.

Ein Vergleich hinsichtlich der Frage, was besser funktioniert oder ob die LLMs den Menschen ersetzen können, wird in dieser Arbeit nicht behandelt. Im Mittelpunkt steht vor allem, die qualitativen Ergebnisse von der Diskussion mit den Expert:innen in ein Prototyps umzuwandeln und auf dieser Basis weitere Erwartungen und Kenntnisse der Proband:innen zu sammeln, die den Prototyp ausprobieren.

1.3. Aufbau der Arbeit

Die Arbeit gliedert sich in mehrer Abschnitte. Zunächst wird der aktuelle Forschungsstand zu großen Sprachmodellen, Bedrohungsmodellierung und Mensch-Maschine-Interaktion dargelegt. Anschließend folgt die Beschreibung der Konzeptentwicklung, beginnend mit einem Workshop, in dem Expert:innen Feedback gaben und zum Ausarbeiten des Konzepts beitrugen. Auf Grundlage der dort gewonnenen Erkenntnisse wurde ein KI-gestützter

Threat Modeling Prototyp für die Bedrohungsmodellierung entwickelt. Dieser wurde dann in einer Nutzerstudie von weiteren Probanden getestet.

Im Workshop wurde in einem Gespräch mit unterschiedlichen Expert:innen diskutiert, wie ein solches System effizient gestaltet werden kann. Auf Grundlage ihrer Feedbacks, Anregungen und Ideen wurde ein funktionaler Prototyp entwickelt. Anschließend wurde durch eine Nutzerstudie analysiert, wie das System von den Beteiligten bewertet, erlebt und verstanden wurde. Dabei standen insbesondere die Nachvollziehbarkeit der LLM-Ausgaben und das Vertrauen an die Präzision im Vordergrund.

Die Arbeit erforscht die Erwartungen und das Verständnis der Proband:innen. Dabei wurden mit einem expert:innenzentrierten Design qualitative Daten erhoben, um die Herausforderung eines KI-gestützten Threat-Modeling-Interfaces durch Beispielen zu verdeutlichen und zu vertiefen. Es sollte dabei keine spezifische Lösung erarbeitet werden, wie ein „perfektes“ System aussehen könnte. Vielmehr stand ausschließlich die Nutzerperspektive im Mittelpunkt.

2. Verwandte Arbeiten

In der aktuellen Forschung zum Threat Modeling lassen sich mehrere Schwerpunkte erkennen. Diese befassen sich mit der Wirksamkeit, Automatisierung und Nutzerfreundlichkeit von Methoden wie STRIDE, DFDs und LLMs. Im Zentrum stehen dabei Fragen nach Genauigkeit und Effizienz sowie nach menschlichen Einflussfaktoren und der Rolle von LLMs in der Bedrohungsidentifikation. Studien zeigen das Potenzial und die Grenzen von LLMs auf.

Bei der Diskussion zum Schluss dieser Arbeit, in der über die Hypothesen und Ergebnisse geschrieben wird, werden diese Arbeiten genutzt um die Hypothesen und Ergebnisse zu belegen, zu erklären, vorallem zu untermauern.

2.1. Automatisiertes Threat Modeling mit LLMs

LLMs können in Kombination mit DFDs die Einschätzung realistischer Bedrohungen verbessern. In diesem Zusammenhang untersuchen Wu et al. die Automatisierung von Threat Modeling mithilfe LLMs. Sie zeigen in ihrer Untersuchung „THREATMODELING-LLM“ [Wu et al., 2024], dass LLMs DFDs aus Systembeschreibungen und Quellcodes ableiten, potenzielle Angriffspunkte klassifizieren und Bedrohungsszenarien erstellen können. Es zeigt sich, dass LLMs in der Lage sind, typische Angriffsmethoden zuverlässig zu erkennen und die STRIDE-Kategorien weitgehend korrekt zuzuordnen. Dieser automatisierte Ansatz spart Zeit und reduziert den manuellen Aufwand erheblich, ersetzt jedoch die menschliche Expertise nicht vollständig. Außerdem treten Einschränkungen insbesondere bei komplexen oder domänenspezifischen Systemen auf. Laut der Untersuchung ist die Güte der Eingangsdaten und das Kontextwissen des Modells entscheidend für die Qualität der generierten DFDs. Ungenauigkeiten bei der Modellierung, die aus fehlerhaften oder lückenhaften Systemdokumentationen resultieren, haben oft negative Auswirkungen auf die Präzision der Bedrohungsanalyse. Die mangelnde Erklärbarkeit der LLM-Ausgaben bleibt ein entscheidendes Problem, besonders in sicherheitsrelevanten Anwendungen, wo Nachvollziehbarkeit von zentraler Bedeutung ist [Wu et al., 2024].

Neben Yang et al. zeigt auch das Tool PILLAR von Mollaefar et al. die Potenziale der Automatisierung im Threat Modeling [Mollaefar et al., 2024]. PILLAR bindet regulatorische Vorgaben wie die DSGVO (EU-Verordnung zum Schutz personenbezogener Daten) und ISO-Normen (internationale Organisation für Normierung) in die Analyse ein. Trotz der vielversprechenden Ansätze für eine datenschutzkonforme Bedrohungsanalyse bestehen zentrale Einschränkungen, darunter ein begrenztes Kontextverständnis des Modells, eine eingeschränkte Nachvollziehbarkeit der Entscheidungen sowie gelegentlich unangemessene oder fehlerhafte Empfehlungen. Zudem wird das Risiko von Overfitting betont [Mollaefar et al., 2024].

Mollaefar et al. präsentieren mit PILLAR ein auf großen LLMs basierendes System zur automatisierten Identifizierung von Datenschutzbedrohungen. Das Tool analysiert DFDs, erkennt potenzielle Bedrohungen basierend auf dem STRIDE-Modell und bewertet die daraus resultierenden Risiken unter Berücksichtigung bewährter Datenschutz- und Sicherheitsstandards wie der DSGVO (GDPR) und ISO 27001. Maschinelles Lernen wird zur automatischen Priorisierung von Bedrohungen eingesetzt, wodurch sich der Threat-Modeling-Prozess effizienter gestalten lässt. Die Studie weist jedoch auch auf wesentliche Limitationen hin: das begrenzte Kontextverständnis von LLMs, die eingeschränkte Transparenz der Modellentscheidungen und vereinzelt ungeeignete Sicherheitsempfehlungen. Darüber hinaus wird das Risiko des Overfittings angesprochen, insbesondere bei der Nutzung nicht ausreichend generalisierbarer Trainingsdaten. Insgesamt unterstreicht PILLAR trotz seines Potenzials die anhaltende Notwendigkeit menschlicher Kontrolle und zusätzlichem Kontextwissens [Mollaefar et al., 2024].

Vertiefend beleuchtet die Studie von Sahoo et al. [Sahoo et al., 2024] das Thema Prompt Engineering als Schlüsselfaktor für die Qualität von LLM-Ausgaben, vor allem in sicherheitskritischen Bereichen wie der Bedrohungsanalyse. Die Autor:innen ordnen verschiedene Techniken zur Verbesserung von Modellantworten ein und zeigen, dass Methoden wie „Chain of Thought“ (CoT) und „Self-Refine“ insbesondere bei komplexen Aufgaben die Genauigkeit erheblich steigern können. Dadurch ergibt sich für das Threat Modeling ein wesentlicher Vorteil: Die Förderung durch LLMs kann durch eine gezielte Gestaltung der Prompts erheblich verbessert werden, ohne dass die Modelle aufwendig nachtrainiert werden müssen. Die Autor:innen wei-

sen ergänzend auf die Verwendung sogenannter Adapter-Modelle hin, die kleinere und effizientere LLM-Varianten ermöglichen. Dadurch werden KI-gestützte Bedrohungsanalysen nicht nur technisch effektiver, sondern auch aus wirtschaftlicher Sicht attraktiver [Sahoo et al., 2024].

Trotz gelegentlicher Kritik an klassischen DFDs verdeutlicht die Untersuchung von Chis et al. [a) Chiş et al., 2024], dass DFDs in Verbindung mit bewährten Verfahren wie STRIDE (ein Bedrohungsmodell, das Sicherheitsrisiken kategorisiert) nach wie vor einen hohen praktischen Wert bieten. Sie unterstützen strukturiertes und systematisches Denken, bringen Klarheit in die Analyse und sind leicht zu erlernen. In ihrem designwissenschaftlichen Ansatz schlagen Chis et al. ein semantisches Modellierungskonzept vor, das klassische DFDs mithilfe von LLMs in maschinenlesbare Wissensgraphen umwandelt. Das Ziel besteht darin, eine frühzeitige Risikoerkennung und eine fundierte Sicherheitsanalyse in komplexen Migrationsszenarien, wie etwa bei der Umstellung auf Cloud-Infrastrukturen, zu ermöglichen. Das Verfahren ermöglicht eine strukturierte und nachvollziehbare Dokumentation von Prozessen, Akteuren und Sicherheitszonen. Es unterstützt Entscheidungsträger:innen bei der Ableitung gezielter Maßnahmen zur Reduzierung von Risiken. Obwohl die Studie noch nicht vollständig veröffentlicht wurde, hebt der Abstract das Potenzial hervor, LLMs bereits in frühen Entwicklungsphasen sinnvoll für Sicherheitsanalysen zu nutzen [a) Chiş et al., 2024].

Aufbauend auf diesen Erkenntnissen konkretisieren Chis et al. [b) Chiş et al., 2024] in einer verwandten Arbeit das Zusammenspiel von STRIDE und DFDs im Kontext von „Secure by Design“. Sie stellen ein Framework vor, das Bedrohungen frühzeitig erkennt, indem es die Secure-by-Design-Prinzipien mit einer systematischen Integration von DFDs und dem STRIDE-Modell verbindet. Am Beispiel eines Online-Shops werden Geschäftsprozesse modelliert und auf sicherheitsrelevante Schwachstellen untersucht. DFDs unterstützen dabei sowohl die Erfassung technischer Risiken, wie beispielsweise Spoofing-Angriffe bei Logins, als auch die Identifizierung nichttechnischer Schwachstellen. Zusammen mit dem STRIDE-Modell erlaubt das Framework eine strukturierte Risikobewertung, zu der auch die Ableitung von Sicherheits-Scores gehört. Diese objektivieren den Analyseprozess und ermöglichen eine fundierte Bewertung potenzieller Bedrohun-

gen. Der Ansatz weist jedoch vor allem bei der Erfassung komplexer und domänenübergreifender Bedrohungsszenarien Schwächen auf. Einerseits hängt er stark von der Qualität und Vollständigkeit der zugrunde liegenden DFDs ab, andererseits ist er bei großen oder dynamischen Systemen nur eingeschränkt skalierbar. Neuartige oder kontextspezifische Bedrohungen werden durch die STRIDE-Kategorisierung zudem nicht immer vollständig erfasst. Dennoch betonen die Autor:innen, dass sich mit der modellbasierten Herangehensweise Sicherheitsstrategien systematisch und kontinuierlich verbessern lassen [b) Chiş et al., 2024].

2.2. Klassische und halbautomatisierte Threat-Modeling-Ansätze

Im Gegensatz zu den automatisierten Ansätzen steht die Untersuchung von Scandariato et al. [Scandariato et al., 2015], die eine der frühesten und umfassendsten Studien zur manuellen Anwendung der STRIDE-Methode durchführte. 57 Masterstudierende der Informatik führten im Rahmen dieser Untersuchung eine Analyse eines verteilten Softwaresystems durch, um die Effektivität und Praktikabilität von STRIDE in einem realitätsnahen Lehrkontext zu bewerten. Die Ergebnisse zeigten, dass STRIDE grundsätzlich erlern- und anwendbar ist. Die Durchführung war jedoch mit einem hohen Zeitaufwand verbunden: Die durchschnittliche Produktivität lag bei lediglich 1,2 bis 1,8 korrekt identifizierten Bedrohungen pro Stunde. Darüber hinaus betrug die durchschnittliche Erkennungsrate weniger als 80 Prozent. Dabei wurden hauptsächlich abstraktere Bedrohungskategorien wie Spoofing (Vortäuschen einer falschen Identität) nicht wahrgenommen. Ein weiteres zentrales Ergebnis der Studie war, dass ein höherer Zeitaufwand nicht zwangsläufig zu besseren Analyseergebnissen führte. Dies ist ein Hinweis darauf, dass die Effizienzsteigerung durch reine Übung begrenzt ist. Die Studie hebt daher sowohl die Möglichkeiten als auch die Einschränkungen der manuellen Anwendung von STRIDE hervor und bietet wesentliche Hinweise auf den Bedarf an unterstützenden Tools oder Automatisierung [Scandariato et al., 2015].

Bereits vor der Verfügbarkeit leistungsstarker LLMs wurde der Automatisierungsgedanke im Threat Modeling verfolgt, wie die Studie von Singh et al. [Singh et al., 2019] zeigt. Sie untersuchten den Einsatz automatisierter

Tools auf Basis erweiterter Datenflussdiagramme (eDFDs) im Vergleich zu traditionellen, manuellen Methoden der Bedrohungsanalyse. Der Fokus der Untersuchung lag auf der eSTRIDE-Methode, die klassische DFDs um zusätzliche Metadaten ergänzt und somit eine strukturierte und automatisierbare Analyse ermöglicht. Zu diesem Zweck wurde ein Prototyp entwickelt, mit dem sich solche eDFDs erstellen und anpassen lassen und der anschließend automatisch Bedrohungen identifiziert. In praktischen Workshops mit Studierenden ohne Vorerfahrung wurde festgestellt, dass die Nutzer:innen des Tools eine deutlich höhere Präzision (74,8 Prozent im Vergleich zu 60 Prozent) und Produktivität (1,4 identifizierte Bedrohungen pro Minute im Vergleich zu 1,2) erzielten als bei manuellen Ansätzen. Der Recall war dabei weitgehend ähnlich. Die Ergebnisse zeigen das Potenzial automatisierter Bedrohungsanalysen zur Effizienzsteigerung, betonen jedoch gleichzeitig die Notwendigkeit einer menschlichen Überprüfung. Denn automatisierte Ansätze erfassen kontextabhängige Bedrohungen nur eingeschränkt, sind stark von der Qualität der Modellierung abhängig und können Fehlklassifikationen ohne fachliche Interpretation nicht zuverlässig erkennen [Singh et al., 2019].

2.3. Menschliche Einflussfaktoren im Threat Modeling

Auf die Rolle menschlicher Einflussfaktoren im Threat Modeling gehen Tuma und Mbaka [Tuma and Mbaka, 2022] in einer theoretisch konzipierten, jedoch nicht umgesetzten Studie ein. Dabei sollte erforscht werden wie menschliche Faktoren wie Geschlecht, kulturelle Herkunft oder Nationalität die Qualität von Bedrohungsanalysen beeinflussen. Auch wenn es keine empirischen Daten gibt, weist die methodische Ausarbeitung darauf hin, dass individuelle Unterschiede in der Wahrnehmung sicherheitskritischer Prozesse erhebliche Auswirkungen auf die Genauigkeit und Objektivität des Threat Modelings haben können. Diese Dimension menschlicher Variabilität lenkt die Aufmerksamkeit auf nicht-technische Einflussfaktoren und betont die Bedeutung interdisziplinärer Perspektiven im Bereich der IT-Sicherheit. Zudem stellt die Studie die Frage, inwieweit standardisierte und automatisierte Analyseprozesse zur Stabilisierung von LLM-basierten Systemen beitragen können. Dennoch empfiehlt die Arbeit zur Vorsicht im Umgang

mit solchen Technologien, insbesondere in Bezug auf potenzielle Bias und das Risiko eines unkritischen Vertrauens in KI-gestützte Entscheidungen. Diese Aspekte wurden in den bestehenden LLM-gestützten Ansätzen bislang kaum berücksichtigt [Tuma and Mbaka, 2022].

2.4. Hybridmodelle: Kombination von DFDs und LLMs

In der aktuellen Studie von Mbaka und Tuma [Mbaka and Tuma, 2024] analysieren sie den Einfluss von DFDs und LLMs, insbesondere ChatGPT-3.5 Turbo, auf die Qualität der Bedrohungsanalyse. Im Rahmen eines kontrollierten Experiments wurden Teilnehmende mit technischem Hintergrund aus den Bereichen Softwareentwicklung und Cybersicherheit in vier Gruppen eingeteilt. Diese Gruppen erhielten jeweils verschiedene Arten von Analysehilfen: Eine Gruppe erhielt keine Unterstützung, eine andere ausschließlich DFDs, eine weitere ausschließlich LLM-Unterstützung und die letzte Gruppe eine Kombination aus beiden. Ihre Aufgabe war es in praxisnahen Szenarien wie GitHub-Updates reale und fiktive Bedrohungen zu erkennen.

Die Ergebnisse verdeutlichen, dass die Kombination aus DFDs und LLM (Gruppe C) zu den besten Ergebnissen führte. Die höchste Treffergenauigkeit wurde mit einem Durchschnitt von 9,4 korrekt identifizierten Bedrohungen aus zehn erreicht. Es fiel jedoch gleichzeitig auf, dass diese Gruppe auch eine erhöhte Anzahl an falsch positiven Ergebnissen produzierte. Die Gruppen, die nur Zugriff auf das LLM hatten, erzielten bei der Identifizierung realistischer Bedrohungen signifikant bessere Ergebnisse als die Gruppen ohne technologische Unterstützung. Bei weniger erfahrenen Teilnehmenden offenbarte sich jedoch ein zentrales Risiko: Sie nahmen die Vorschläge des LLM oft ohne kritische Prüfung an. Dies deutet auf eine mögliche Übernahme von Empfehlungen durch Maschinen hin. Die Studie gilt als einer der bisher methodisch differenziertesten empirischen Ansätze zur Evaluation von LLM- und DFD-gestützten Threat-Modeling-Prozessen. Sie macht sowohl das Potenzial für eine Leistungssteigerung durch KI-gestützte Systeme als auch die damit verbundenen Herausforderungen in Bezug auf Nachvollziehbarkeit und menschliches Urteilsvermögen deutlich [Mbaka and Tuma, 2024].

2.5. Zusammenfassung der Verwandete Arbeiten

Zusammenfassend lässt sich aus der aktuellen Studienlage ableiten, dass große Sprachmodelle das Threat Modeling nicht ersetzen, sondern als leistungsfähige Ergänzung zu etablierten Methoden betrachtet werden können. Die Verbindung traditioneller Methoden wie DFDs und des STRIDE-Modells mit modernen, KI-gestützten Werkzeugen zeigt besonders vielversprechende Ansätze. DFDs bieten eine bewährte visuelle Grundlage für die systematische Analyse von Systemarchitekturen, während LLMs in Kombination mit STRIDE eine automatisierte und beschleunigte Identifikation und Klassifikation potenzieller Bedrohungen ermöglichen. Forschungen haben nahegelegt, dass diese hybride Herangehensweise die Effizienz und Qualität der Bedrohungsanalyse signifikant steigern kann. LLMs übernehmen dabei Aufgaben wie das automatische Ableiten von Bedrohungsszenarien aus Quellcode oder Systemdokumentationen. Dadurch wird eine zugängliche, natürlichsprachliche Verarbeitung sicherheitsrelevanter Informationen gefördert. Der menschliche Faktor ist jedoch weiterhin von zentraler Bedeutung: Nur durch ein fundiertes Verständnis der verwendeten Modelle, eine kritische Reflexion der Ergebnisse und gezielte Anpassungen an den spezifischen Anwendungskontext kann das volle Potenzial solcher Systeme ausgeschöpft werden. Zahlreiche Studien weisen jedoch gleichzeitig auf bestehende Herausforderungen hin. Hierzu gehören beispielsweise Gefahren, die aus Overfitting resultieren, aus einer nicht adäquaten Modellierung komplexer oder domänenspezifischer Systeme sowie aus der eingeschränkten Nachvollziehbarkeit bestimmter Ergebnisse von LLM-Generierungen. Das nachhaltige Gelingen automatisierter Bedrohungsanalysen beruht vor diesem Hintergrund vor allem auf der Zusammenarbeit von Mensch und Maschine. Von ausschlaggebender Bedeutung ist, dass die spezifischen Stärken beider Seiten zum Einsatz kommen und ihre Grenzen bedacht berücksichtigt werden.

3. Methodik

Die Studie verfolgt das Ziel, den Einsatz eines LLMs wie ChatGPT 4.0 zur Bedrohungsanalyse auf Basis von DFDs nach dem STRIDE-Modell mit einem nutzerzentrierten Prototyp zu testen. Dazu wurde ein mehrstufiges, exploratives methodisches Vorgehen gewählt, um qualitative Erkenntnisse über die technische Umsetzbarkeit sowie die Erwartungshaltung und das Verständnis der Nutzenden zu gewinnen.

Der gesamte Prozess der Entwicklung und Evaluation fand in einer Nutzerstudie statt. Im Workshop wurde das methodische Konzept erarbeitet und validiert, in der Nutzerstudie wurde dann der entwickelte Prototyp praktisch getestet. Das Ziel dieser Untersuchung war nicht, verschiedene Tools oder Methoden direkt zu vergleichen. Stattdessen ging es vor allem darum herauszufinden, ob und wie der gesamte Ablauf funktionieren kann, vom Eingeben eines DFD über die automatische Analyse mit STRIDE bis hin zur menschlichen Bewertung und Nutzung in der Praxis. Es handelt sich hier um eine explorative Studie, die Hinweise darauf geben soll, wie sich KI-Modelle wie LLMs in sicherheitsrelevanten Softwareentwicklungsprozessen integrieren lassen könnten.

3.1. Workshop

Im Folgenden wird die Durchführung und Auswertung der Experten-Diskussion zur Bewertung des vorgestellten KI-gestützten Threat-Modeling-Ansatzes beschrieben.

3.1.1. Teilnehmer:innen

An der Studie nahmen drei Fachleute aus dem Bereich Informatik teil: eine Frau und zwei Männer mit unterschiedlichen Kenntnisniveaus im Bereich IT-Sicherheit. Die erste Teilnehmerin ist 45 Jahre alt, Informatikerin und verfügt über grundlegendes IT-Sicherheitswissen. Sie bringt insbesondere Erfahrung im Umgang und Entwicklung von LLMs mit. Der zweite Teilnehmer ist 42 Jahre alt, ebenfalls Informatiker, und besitzt fortgeschrittenes

IT-Sicherheitswissen. Er ist in der Forschung zu Sicherheitsthemen sowie zur statischen Programmanalyse unter Einsatz von Machine Learning tätig. Der dritte Teilnehmer ist ebenfalls Informatiker und verfügt über fortgeschrittene Kenntnisse im Bereich IT-Sicherheit sowie umfassende praktische Erfahrung in Sicherheitsanalysen und -prüfungen.

Alle Teilnehmer:innen unterzeichneten eine Einverständniserklärung zur Audioaufzeichnung. Durch die gezielte Auswahl dieser Fachpersonen wurde eine ausgewogene Kombination aus praktischer Expertise und wissenschaftlicher Forschungskompetenz im Bereich IT-Sicherheit und Softwareentwicklung gewährleistet. Alle Teilnehmer:innen unterzeichneten eine Einverständniserklärung zur Audioaufzeichnung. Diese wurde ausschließlich für die Auswertung der Studie verwendet.

3.1.2. Materialien

Im Workshop wurde das methodische Konzept den genannten Teilnehmern aus den eben genannten Disziplinen vorgestellt. Zur Einführung gehören die zentralen Begriffe des Threat Modeling, insbesondere DFDs und STRIDE, die Zielsetzung der Analyse und ein Überblick über die vorhandene Forschung in Form einer Präsentation. Anschließend wurde anhand eines Beispielvideos demonstriert, wie ChatGPT 4.0 mit einem DFD „gefüttert“ und eine STRIDE-Analyse durchführt wird. Auf Basis dieses Videos diskutieren die Teilnehmenden, ob die Analyse nachvollziehbar sei, ob zentrale Aspekte fehlen würden und wie verständlich die Argumentation des Modells wirke. Die Teilnehmer:innen waren sich einig, dass dieses Vorgehen in seiner derzeitigen Form nicht ausreicht, um eine effektive Unterstützung für das Threat Modeling zu bieten. Kritisch angemerkt wurde vor allem, dass die Input-Prompts, die Output-Analyse und das damit verbundene Vertrauen nur als ausreichend gelten. Ein strukturierterer Ansatz, der das DFD besser erklärt und beschreibt, um eine fundierte Analyse zu ermöglichen, fehlte. Im Anschluss richtete sich der Fokus der Debatte auf die Frage, welche Zielgruppe für ein KI-gestütztes Threat-Modeling-Tool geeignet sei.

3.1.3. Durchführung

Zu Beginn wurde eine kurze Einschätzung des Fachwissens der Teilnehmer:innen in IT-Sicherheit abgefragt, wobei die Teilnehmer:innen ihr Wissen in den Bereichen IT-Sicherheit und Softwareentwicklung als weitreichend einschätzten, während die LLM-Expertin ihr Wissen in diesem Bereich als geringfügig einschätzte.

Im Verlauf des Workshops bewerteten die Teilnehmer:innen die vorgestellte Idee eines KI-gestützten Threat-Modeling-Assistenten. Dazu wurde zunächst ein Live-Voting durchgeführt, bei dem die Teilnehmer:innen anonym zu den Themen Sinnhaftigkeit des Vorgehens, spezifische Herausforderungen der jeweiligen Disziplinen und Rolle des menschlichen Inputs abstimmen konnten. Weitere wichtige Themen waren das Vertrauen in KI-gestützte Systeme und die optimale Aufbereitung von Informationen, um die Kommunikation der Nutzer mit dem Tool zu verbessern. Es wurden Fragen zum groben Feedback gestellt: Eignet sich Chat GPT als Threat-Modeling-Hilfstooll? Was könnte Chat GPT noch an In- oder Output benötigen? Welche Erwartungen werden an ein solches System gestellt? Gibt es überhaupt einen Bedarf in den drei verschiedenen Arbeitsbereichen? Um die Diskussion anzuregen und eine immer genauere Vorstellung vom Interface zu entwickeln, wurden auch konkretere Fragen zu Funktionalität, Usability und Design gestellt. Gegen Ende wurde auch noch einmal über die Vertrauenswürdigkeit, Transparenz und Nachvollziehbarkeit von LLMs wie ChatGPT diskutiert. Dies ist ein entscheidender Faktor dafür, ob ein Interface dies schaffen kann und wie Vertrauen in das Tool erzeugt werden kann.

3.1.4. Auswertung

Im Folgenden werden die im Workshop gewonnenen Ergebnisse dargestellt, die als konzeptionelle Grundlage für das nachfolgende Prototyp-Design dienen. Die relevanten Erkenntnisse werden bereits an dieser Stelle erläutert, da sie für die Prototypentwicklung sowie für die abschließende Nutzerstudie mit diesem Prototypen erforderlich sind.

3.1.5. Prototyp

In diesem Abschnitt wird die Prototypentwicklung auf Grundlage der Workshop-Ergebnisse erklärt. Ein interaktiver Prototyp als Assistenzsystem wurde entwickelt, um die Bedrohungsanalyse auf DFDs basierend mit großen Sprachmodellen wie Chat-GPT strukturiert zu unterstützen. Dies geschah auf Grundlage der Erkenntnisse aus dem Workshop. Die Zielsetzung umfasste die Demonstration der technischen Machbarkeit, aber vor allem die Entwicklung eines nutzerzentrierten Tools. Aus diesem Grund wurde der Prototyp genau in Übereinstimmung mit den von den Fachleuten genannten Herausforderungen und Nutzerbedarfen entwickelt. Die Umsetzung erfolgte als webbasierte Anwendung auf Basis von Streamlit, die eine dialogorientierte Interaktion mit einem großen Sprachmodell erlaubt und gleichzeitig strukturierte Eingaben und Ausgaben unterstützt. Der fertige Prototyp ist in Abbildung 2 zu sehen.

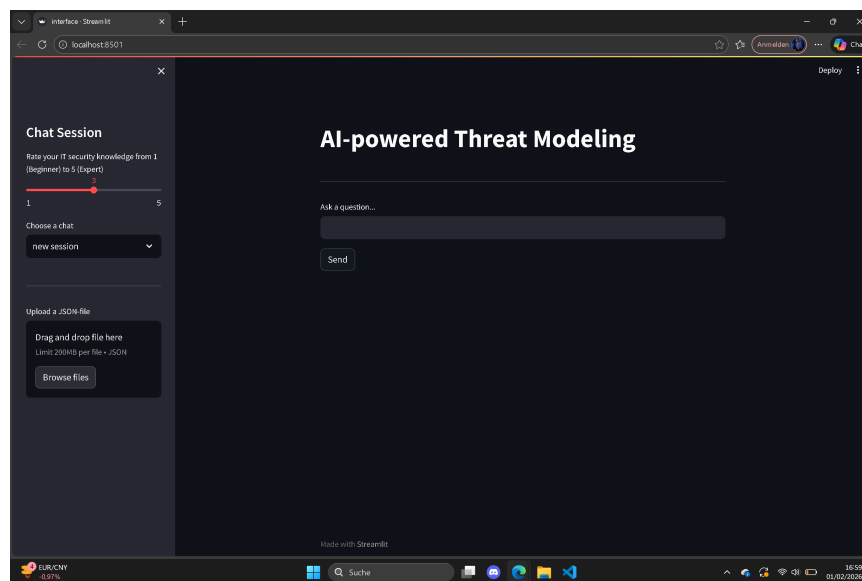


Abbildung 2: Interface Screenshot

1. Allgemeine Herausforderungen: Die Ergebnisse des Workshops zeigen deutlich, dass die Nachvollziehbarkeit und Qualität KI-gestützter Threat-Modeling-Analysen stark vom bereitgestellten Kontext abhängen. Bei sehr generischem oder kontextarmem Input, insbesondere in sogenannten „Grüne-Wiese“-Szenarien ohne klar definierte Systemgrenzen oder Sicherheitsannah-

men, lieferten große Sprachmodelle nur eingeschränkt hilfreiche Ergebnisse. Dies erschwerte es den Teilnehmenden, die Analyseergebnisse als belastbar und nachvollziehbar einzuordnen.

Ein zentrales Problem bestand zudem in der Unvollständigkeit klassischer Data-Flow-Diagramme. Diese enthalten häufig keine expliziten Informationen zu tatsächlich implementierten Sicherheitsmaßnahmen, wodurch eine Diskrepanz zwischen modellierter Architektur und realem Systemzustand entsteht. Diese Lücke wirkte sich unmittelbar auf die Qualität der KI-generierten Bedrohungsanalysen aus. Im Prototyp wurde diesem Problem begegnet, indem fehlende oder implizite Informationen nicht automatisch ergänzt werden, sondern explizit als Unsicherheiten oder offene Punkte in der KI-Antwort benannt werden.

In diesem Zusammenhang wurde wiederholt betont, dass die Güte der Analyse maßgeblich von der Qualität des zugrunde liegenden DFDs abhängt. Unvollständige, fehlerhafte oder zu abstrakte Darstellungen führten zu unpräzisen oder missverständlichen Ergebnissen. Ein einmaliger, vollständig automatisierter Analyseansatz wurde daher von allen Teilnehmenden als ungeeignet bewertet. Stattdessen wurde Threat Modeling als iterativer Prozess verstanden, der schrittweise verfeinert werden muss. Diese iterative Logik wurde technisch durch einen persistierten Chatverlauf umgesetzt, der es erlaubt, frühere Analysezustände wieder aufzugreifen und gezielt weiterzuentwickeln.

Aus diesen Beobachtungen ergab sich die klare Anforderung, dass Nutzende aktiv dazu angeleitet werden müssen, möglichst viele relevante Informationen bereitzustellen. Gleichzeitig sollte das System fehlenden Kontext nicht stillschweigend kompensieren, sondern gezielt Rückfragen stellen. Trotz der Unterstützung durch KI wurde übereinstimmend festgestellt, dass eine vollständig autonome Bewertung nicht möglich sei und menschliche Kontrolle sowie manuelle Anpassungen unverzichtbar bleibe. Deswegen wurde die KI so implementiert, dass am Ende jeder Frage weitere Nachfragen oder Ideen gegeben werden, was als nächstes passieren soll, wie in Abbildung 3 gezeigt wird. Technisch basiert dies auf einer separaten Analysefunktion, die den bisherigen Dialog auswertet und daraus gezielt Vorschläge für fehlende Informationen, nächste Schritte oder präzisierende Rückfragen ableitet.

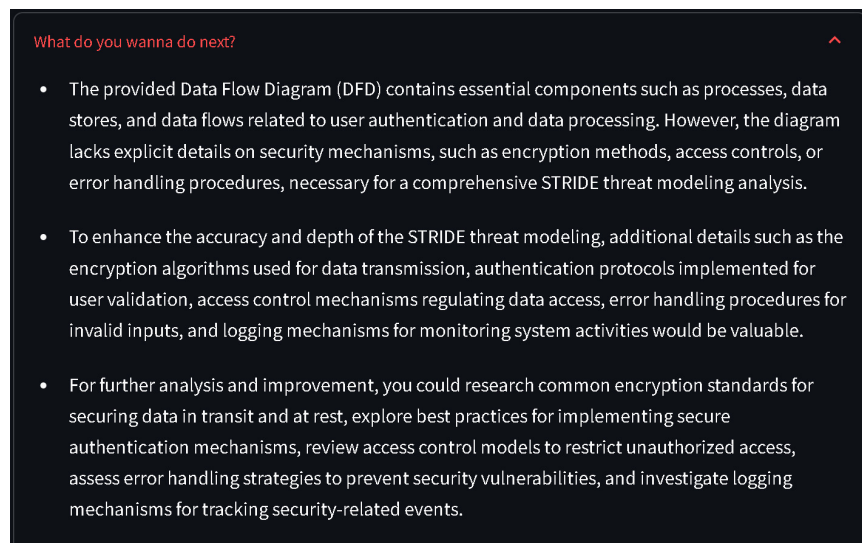


Abbildung 3: Interface Screenshot - KI Vorschläge

2. Eingabeformate und Datenquellen: Die Ergebnisse zeigten eine deutliche Präferenz für textuelle und strukturierte Eingabeformate. Bildbasierte Darstellungen von DFDs, etwa als PNG oder PDF, wurden als problematisch eingeschätzt, da ihre semantische Struktur von großen Sprachmodellen nur eingeschränkt zuverlässig erfasst werden kann. Dies wirkte sich negativ auf die Genauigkeit und Nachvollziehbarkeit der Analyse aus. Eine visuelle, bildbasierte Darstellung konnte aus zeitlichen Gründen nicht implementiert werden.

Demgegenüber wurden strukturierte Formate wie JSON oder YAML als besonders geeignet bewertet. Sie ermöglichen eine eindeutige Beschreibung von Systemkomponenten, Datenflüssen und Annahmen und können direkt von der KI verarbeitet werden. Darüber hinaus wurde positiv hervorgehoben, dass strukturierte Ausgaben der Analyse selbst – etwa in Form von JSON – eine Weiterverarbeitung, Kürzung oder Integration in andere Werkzeuge erlauben. Dies erhöht die praktische Nutzbarkeit der Ergebnisse und unterstützt einen iterativen Arbeitsprozess. Daher wurde die KI mit einer Upload-Funktion für JSON-Dateien ausgestattet, wie in Abbildung 4 dargestellt. Nach dem Upload werden die Datenflüsse automatisch nummeriert und angereichert, sodass sie innerhalb der Analyse eindeutig referenzierbar sind. Dies erleichtert sowohl die Diskussion einzelner Bedrohungen als auch deren spätere Nachverfolgung.

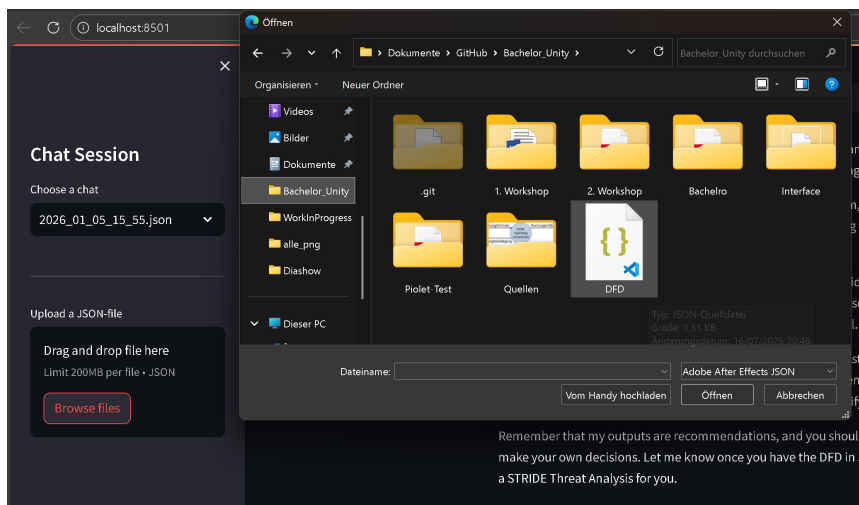


Abbildung 4: Interface Screenshot - JSON Upload

3. Zielgruppen und Benutzerprofile: Die Teilnehmenden machten deutlich, dass ein KI-gestütztes Threat-Modeling-Tool sehr unterschiedliche Zielgruppen anspricht, deren Bedürfnisse stark variieren. Personen ohne vertiefte IT-Sicherheitskenntnisse empfanden die Tiefe und Komplexität der KI-Ausgaben teilweise als überfordernd. Daraus ergab sich der Bedarf an didaktisch aufbereiteten Erklärungen und einer schrittweisen Einführung in sicherheitsrelevante Konzepte.

Entwickler:innen legten hingegen besonderen Wert auf praxisnahe Informationen, etwa zu Sicherheitsframeworks, Bibliotheken oder konkreten Implementierungsansätzen. Besonders kleine Unternehmen, Start-ups und Freelancer:innen wurden als Zielgruppe identifiziert, da dort spezialisiertes Sicherheitswissen häufig fehlt oder erst spät aufgebaut wird. Für diese Gruppen kann ein KI-gestütztes Assistenzsystem einen erheblichen Mehrwert darstellen.

Ein integrierter Regler im Interface sorgt dafür, dass die KI auf unterschiedliche Wissensstände der Nutzer:innen eingeht. Anfänger:innen erhalten leicht verständliche Erklärungen inklusive Fachbegriffsdefinitionen im Textformat, während erfahrene Expert:innen davon ausgehen können, dass Fachbegriffe bekannt sind, und auf Wunsch die Informationen kompakt in strukturierter Form, etwa als JSON-Datei, erhalten. Dieser Regler beeinflusst direkt das Prompt-Design und steuert unter anderem Erklärungstiefe, Terminologie

sowie das Ausgabeformat der KI-Antworten. So passt sich das System flexibel den individuellen Bedürfnissen der Nutzer:innen an. Die Abbildung 5 zeigt den implementierten Regler des Interfaces.

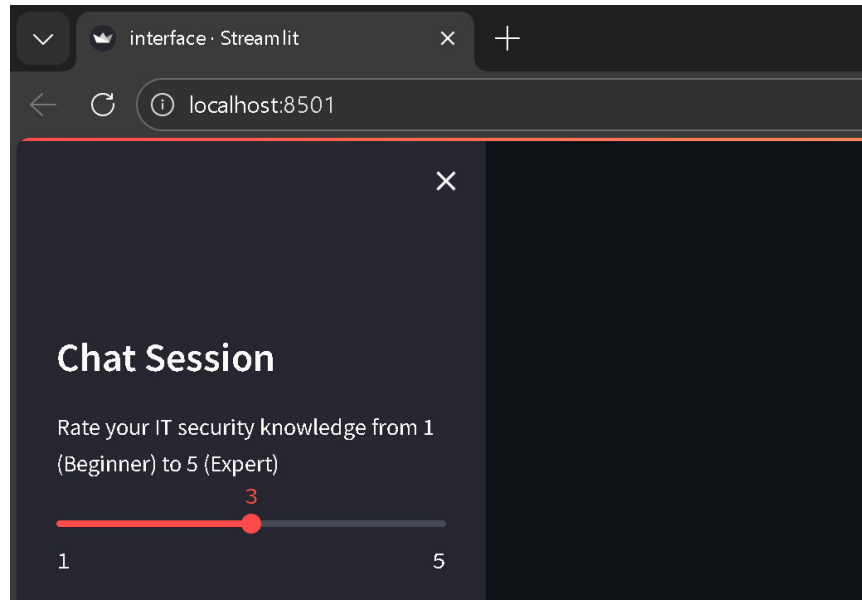


Abbildung 5: Prototyp Screenshot - Wissensstand Regler

Erfahrene IT-Sicherheitsfachkräfte sahen das System weniger als Ersatz menschlicher Expertise, sondern vielmehr als ergänzendes Werkzeug, etwa zur Zweitprüfung oder zur kritischen Reflexion bestehender Annahmen. Daraus ergab sich die zentrale Forderung, das System an unterschiedliche Benutzerprofile anzupassen und die Erklärungstiefe abhängig vom individuellen Vorwissen zu variieren.

4. Interaktion und Nutzerführung: Ein wesentliches Ergebnis des Workshops betrifft die Gestaltung der Interaktion zwischen Nutzenden und System. Die Möglichkeit, einzelne Datenflüsse eindeutig zu referenzieren, wurde als hilfreich bewertet, um gezielt über spezifische Bedrohungen zu diskutieren. Dies konnte aus Zeitgründen nicht visualisiert werden. Die technische Grundlage hierfür wurde jedoch bereits geschaffen, indem jeder Datenfluss intern mit einer eindeutigen ID versehen wird.

Darüber hinaus wurde betont, dass das System aktiv Rückfragen stellen sollte, wenn Informationen fehlen oder Annahmen unklar sind, anstatt implizite

Schlussfolgerungen zu ziehen. Aus diesem Grund wurde ein dialogbasierter Chat mit der KI implementiert, der gezielte Fragen und Rückfragen ermöglicht, wie in Abbildung 6 dargestellt. Der Chat erlaubt es, Analyse, Rückfragen und Nutzereingaben in einem fortlaufenden Kontext zu verbinden und schrittweise zu verfeinern.

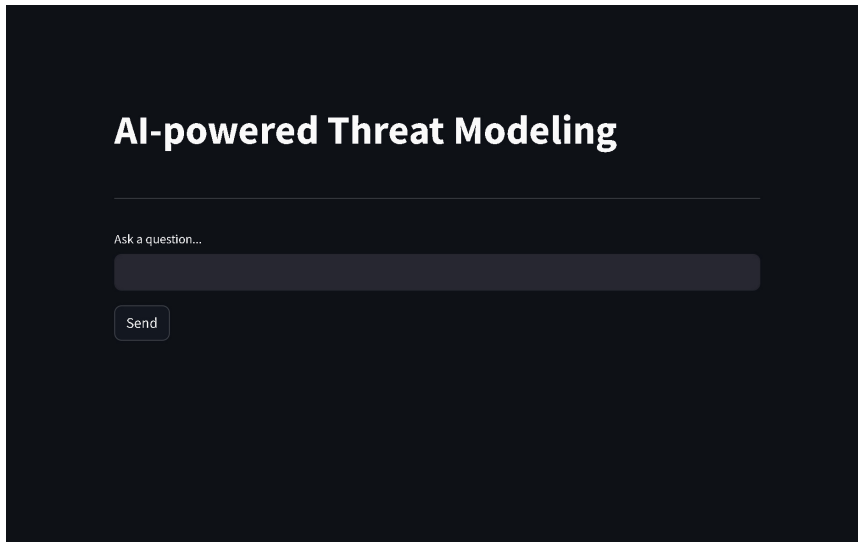


Abbildung 6: Prototyp Screenshot - Chat

Threat Modeling wurde klar als iterativer Prozess verstanden, der sich an agilen oder zyklischen Entwicklungsmodellen orientiert. Entsprechend äußerten die Teilnehmenden den Wunsch, frühere Analysezustände erneut aufgreifen und fortführen zu können. Das Tool sollte nicht nur analysieren, sondern die Nutzenden aktiv bei der Weiterentwicklung und Verbesserung ihrer DFDs unterstützen. Dafür wurde, wie Abbildung 7 zeigt, eine Session-Drop-Down-List eingebaut durch die man zu alten Chaträumen zurück kommen kann. Die zugehörigen Chatverläufe werden dabei persistent gespeichert und können jederzeit wieder geladen werden.

Zudem wurde eine stärkere Nutzerführung gefordert, etwa durch Hinweise darauf, welche Informationen noch fehlen oder welche Aspekte bereits berücksichtigt wurden. Die Ergebnisse der KI sollten dabei strukturiert und übersichtlich aufbereitet werden, da unformatierte Chat-Ausgaben als wenig hilfreich wahrgenommen wurden.

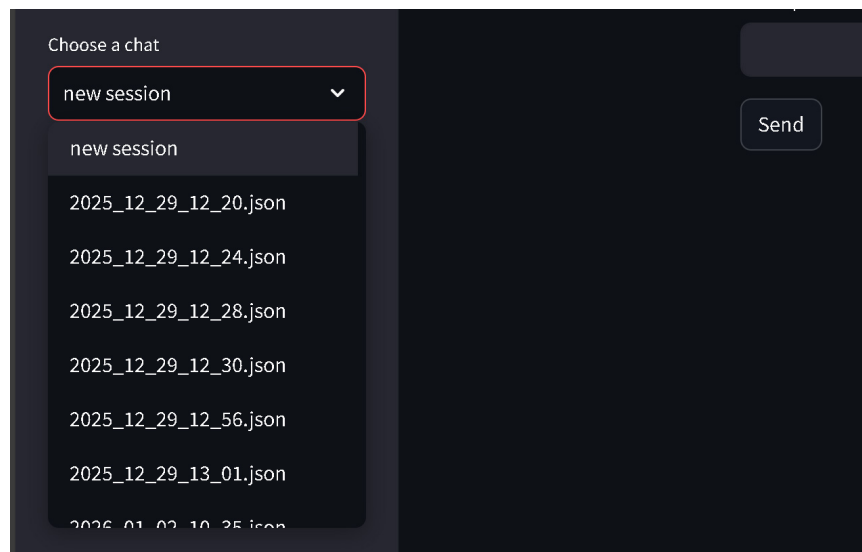


Abbildung 7: Prototyp Screenshot - Sessions

5. Prompt-Design und Automatisierung: Prompt-Vorlagen wurden von den Teilnehmenden grundsätzlich als hilfreiche Unterstützung bewertet, insbesondere beim Einstieg in komplexe oder fachfremde Themenbereiche. Gleichzeitig wurde auf die Gefahr hingewiesen, dass vorgegebene Prompts die Denkweise der Nutzenden zu stark beeinflussen und alternative Perspektiven einschränken könnten. Prompt-Vorlagen oder Bibliotheken konnten aufgrund begrenzter Zeit nicht eingebaut werden. Stattdessen wurde ein festes, systemseitiges Prompt-Design umgesetzt, das die KI explizit dazu anhalten soll, Unsicherheiten, fehlende Informationen und notwendige Rückfragen offen zu benennen.

Ein zentrales Risiko wurde in einer möglichen Überautomatisierung gesehen. Insbesondere in sicherheitsrelevanten Kontexten besteht die Gefahr, dass Nutzende den KI-Ausgaben unkritisch vertrauen. Als möglicher Gegenansatz wurde vorgeschlagen, Ergebnisse mit bekannten Mustern oder externen Referenzen abzugleichen, um die Qualität und Verlässlichkeit der Analyse zu erhöhen. Dieser Abgleich sollte dabei nicht nur extern erfolgen, sondern auch explizit innerhalb der KI-Antworten sowie im Abschnitt „What to do next?“ (Abbildung 3) berücksichtigt werden, um Nutzende gezielt zu weiterführenden Prüf- und Validierungsschritten anzuleiten. Diese Funktion wurde technisch durch eine separate Auswertung des bisheri-

gen Dialogs realisiert, die konkrete nächste Schritte und Prüfeempfehlungen generiert.

6. Transparenz und Vertrauenswürdigkeit: Die Ergebnisse verdeutlichen den engen Zusammenhang zwischen Transparenz und wahrgenommener Vertrauenswürdigkeit. Die Teilnehmenden betonten, dass Unsicherheiten und Grenzen der Analyse explizit kommuniziert werden müssen, um Vertrauen in die Ergebnisse aufzubauen. Eine offene Darstellung von Annahmen und fehlenden Informationen wurde als glaubwürdigkeitssteigernd wahrgenommen. Dies musste in der Nutzerstudie innerhalb der KI-Antworten getestet werden, um zu prüfen, ob die Umsetzung tatsächlich Vertrauen schafft.

Darüber hinaus zeigte sich, dass die gewünschte Erklärungstiefe stark vom jeweiligen Nutzerprofil abhängt. Während Expert:innen knappe, faktenorientierte Ausgaben bevorzugen, benötigen weniger erfahrene Nutzende ausführlichere Erläuterungen. Ein expliziter Hinweis auf die grundsätzliche Fehleranfälligkeit großer Sprachmodelle wurde als notwendig erachtet, um unrealistische Erwartungen zu vermeiden. Dieser Aspekt wurde auch mithilfe des Wissensstand-Reglers aus Abbildung 5 umgesetzt, da jede Stufe unterschiedlich gewünschte Erklärungstiefen erzeugen soll.

7. Zielbild für das Tool: Aus den Ergebnissen ergibt sich das Zielbild eines interaktiven Assistenzsystems, das Nutzende aktiv durch den Threat-Modeling-Prozess begleitet. Der Schwerpunkt liegt dabei auf der Identifikation potenzieller Bedrohungen und der Unterstützung bei der Modellierung, nicht auf der automatisierten Ableitung vollständiger Sicherheitslösungen.

Insbesondere für erfahrene Fachkräfte eignet sich das System als Review- und Checklisten-Werkzeug, um sicherheitsrelevante Annahmen systematisch zu überprüfen. Ein vollständiger Ersatz menschlicher Expertise wird ausdrücklich nicht angestrebt. Vielmehr versteht sich das Tool als unterstützendes Element innerhalb eines menschlich gesteuerten, iterativen Sicherheitsprozesses.

3.2. Prototyp Useability Test

Nachdem der entwickelte Prototyp die zahlreichen im Workshop formulierten Anforderungen in einem LLM-basierten Tool abbildet, wurde ein UI/UX-Design-Pilot-Test mit zwei Probanden durchgeführt.

3.2.1. Teilnehmer:innen

Die Teilnehmende kommen aus den Bereichen der Informatik. Die Tester:innen verfügten über grundlegende Kenntnisse eines guten Designs, wobei einer der beiden zusätzlich über eine vertiefte Expertise im UI-Design verfügte. Vor Beginn des Tests unterschrieben die Teilnehmer:innen eine Einverständniserklärung, die es erlaubte, das Feedback per Audio aufzuzeichnen und anschließend für die Analyse auszuwerten.

3.2.2. Materialien

Getestet wurde der Prototyp zur Bedrohungsanalyse, inklusive eines DFDs für Test-Szenarien, JSON-Uploader und Chatbereich für die Interaktion, der entwickelt wurde nach den vorher erarbeiteten Aspekten.

3.2.3. Durchführung

Den Probanden wurde zunächst eine kurze Einführung in das Thema „KI-gestütztes Threat Modelling“ gegeben. Im Verlauf des Tests zeigte sich, dass die linke Sidebar stärker genutzt werden sollte, insbesondere in Bezug auf den JSON-Uploader, die IT-Security-Knowledge-Skala sowie den Chatbereich. Außerdem stellte sich heraus, dass die Nutzerfragen mit all den zusätzlichen Informationen zu umfangreich waren und nicht direkt angezeigt werden sollten; besser wäre hier eine Anzeige als Pop-up. Abgesehen von diesen Punkten wurde das Design insgesamt als intuitiv, übersichtlich und gut verständlich wahrgenommen.

3.2.4. Auswertung

Ein zusätzliches Feedback von einer zusätzlichen Expertin für LLMs zeigte Potenziale für eine erhöhte Interaktivität auf. Unter anderem wurde empfohlen, JSON-Dateien oder Bilder anklickbar zu gestalten, um eine direkte Interaktion zu ermöglichen. Als wünschenswerte Erweiterungen wurden zudem die Visualisierung der Inhalte sowie die Option, JSON-Dateien nicht nur hoch-, sondern auch herunterzuladen und interaktiv zu bearbeiten, genannt. Die Anmerkungen bieten wichtige Ansatzpunkte für zukünftige Iterationen, um die Benutzerfreundlichkeit und Effizienz des Prototyps weiter zu verbessern.

3.3. Nutzerstudie

Im Folgenden werden die Durchführung und Auswertung der Studie zur Bewertung des vorgestellten KI-gestützten Threat-Modeling-Interfaces beschrieben.

3.3.1. Teilnehmer:innen

Insgesamt nahmen 13 Personen an der Studie teil. Die Teilnehmenden verfügten überwiegend über einen beruflichen oder ausbildungsbezogenen Hintergrund im IT-Bereich, insbesondere in den Bereichen Softwareentwicklung, Systemadministration, Webentwicklung, IT-Architektur sowie angrenzenden Bereichen wie IT-Produktmanagement und Lehre. Auch Personen in Ausbildung oder Studium sowie Personen mit früherer Tätigkeit im IT-Umfeld waren vertreten.

Das Alter der Teilnehmenden verteilte sich über eine breite Spanne von 25 bis 65 Jahren (Mittelwert=38,08, Standardabweichung=14,14), wobei die meisten Altersgruppen jeweils durch eine Person vertreten waren. Zwei Teilnehmende waren weiblich, elf männlich.

3.3.2. Hypothesen und Untersuchungsfokus

Im Rahmen der Studie wurden drei zentrale Hypothesen formuliert, die den Einfluss der Eingabegestaltung, der Transparenz und der Interaktivität auf die Nutzung des KI-gestützten Threat-Modeling-Systems untersuchten.

- H1 (Verständlichkeit & Transparenz): Die Nachvollziehbarkeit der durch den KI-Assistenten erzeugten Threat-Modeling-Ergebnisse hängt maßgeblich von der Qualität, Struktur und Kontexttiefe der bereitgestellten Eingaben (z. B. DFDs und ergänzende Beschreibungen) ab.
- H2 (Vertrauen): Die wahrgenommene Vertrauenswürdigkeit des KI hängt stark von der Transparenz der Kommunikation von Unsicherheiten und Grenzen der Analyse ab.
- H3 (Interaktion/ User-Experience): Ein interaktiver, dialogbasierter Prozess (z. B. Rückfragen des Systems bei unvollständigen DFDs) wird von den Teilnehmer:innen positiver bewertet als eine einmalige, statische Analyse.

Die Hypothesen wurden anhand der Bearbeitung der drei Szenarien, der Antworten im Google-Formular-Fragebogen sowie der Beobachtungen während der Nutzung des Prototyps überprüft. Die Auswertung erfolgte qualitativ anhand der Fragebogen-Items und der dokumentierten Interaktionen mit der Benutzeroberfläche.

3.3.3. Materialien

Zur späteren Bearbeitung und Auswertung des Feedbacks wurde die Teilnahme durch Screenrecording, Audioaufnahme des Zoom-Meetings² und einen Google Formular-Fragebogen³ dokumentiert. Zu jedem der drei Szenarien gab es die gleichen 13 Fragen:

²<https://www.zoom.com>

³<https://docs.google.com/forms>

H1: Verständlichkeit & Transparenz

1. Die Analyse des Systems war leicht verständlich.
2. Ich konnte nachvollziehen, wie das System zu seinen Ergebnissen gelangt ist.
3. Die Begründungen des Systems waren klar und gut strukturiert.
4. Das System hat Unsicherheiten oder Einschränkungen deutlich kommuniziert.

H2: Vertrauen

5. Ich halte die Analyseergebnisse des Systems für zuverlässig.
6. Ich würde den Ergebnissen in einer realen Arbeitssituation vertrauen.
7. Das System ging ehrlich mit Unsicherheiten um.

H3: Interaktion / User Experience

8. Die Interaktion mit dem System war hilfreich.
9. Ich hatte bei der Nutzung des Systems stets das Gefühl, die Kontrolle zu behalten.
10. Die Eingabeaufforderungen/Fragen des Systems waren sinnvoll und unterstützend.
11. Die Nutzung des Systems war einfach und angenehm.

Zusammenfassende Einschätzung

12. Zusätzliches Feedback zum Szenario: Was hat Ihnen besonders gefallen oder nicht gefallen? Und warum?
13. Insgesamt war das Szenario für mich nützlich.

Vor dem Beginn der Nutzerstudie, die in einem Zoom-Meeting stattfand, hat jeder Teilnehmende eine Einwilligungsbcheinigung als Zustimmung zu den Aufnahmen unterzeichnet. Auch an dieser Stelle erfolgt zunächst eine Erläuterung der Schlüsselbegriffe Threat Modeling, DFDs und STRIDE. Die Teilnehmer:innen sollten das Interface verwenden, um sich diese Begriffe von der KI erklären zu lassen. Eine Beispiel-DFD, die eine einfache Authentifizierung im JSON-Format darstellt, wurde zur Erklärung der DFD verwendet. Auch die KI wird später mit dieser arbeiten. Der Google Formular-Fragebogen wurde entsprechend der Studie zu den jeweiligen Szenarien ausgefüllt. Die Studie nutzte die abgeschlossene Version des Web-App-Prototyps, DFDs für drei Test-Szenarien und Google Forms zur Dokumentation der Szenario-Bearbeitung.

3.3.4. Durchführung

Daraufhin erfolgte die Durchführung der Nutzerstudie. Die Teilnehmer:innen bearbeiteten nacheinander drei vorgegebene Szenarien. Während der Bearbeitung war die Mausfreigabe aktiv, sodass die Interaktionen mit der Benutzeroberfläche beobachtet werden konnten. Parallel dazu füllten die Teilnehmer:innen für jedes Szenario einen Google Formular - Fragebogen aus, um ihre Einschätzungen, Entscheidungen und Wahrnehmungen unmittelbar zu dokumentieren.

Die Studie folgte einem szenariobasierten Ansatz, um unterschiedliche Nutzungskontexte des KI-gestützten Threat-Modeling-Assistenten abzubilden. Die drei Szenarien waren bewusst aufeinander aufbauend gestaltet und unterschieden sich hinsichtlich des bereitgestellten Kontexts und der Komplexität der Aufgabenstellung.

3.3.4.1. Szenario 1: Automatisiertes Threat Modeling auf Basis eines DFD In diesem Szenario luden die Teilnehmer:innen ein vorgegebenes Data-Flow-Diagramm (DFD) im JSON-Format in den Prototyp hoch und ließen eine Threat-Modeling-Analyse auf Basis des STRIDE-Modells durch den KI-Assistenten durchführen. Das Ziel dieses Szenarios bestand darin, zu untersuchen, wie verständlich, nachvollziehbar und hilfreich die automatisch

generierten Ergebnisse bei minimalem Kontext sind. Dabei lag besonderes Augenmerk auf der Klarheit der Ausgaben, der Struktur der Analyse sowie der Einschätzung, ob die identifizierten Bedrohungen plausibel und nachvollziehbar erscheinen.

3.3.4.2. Szenario 2: Kontextanreicherung und iterative Analyse Im zweiten Szenario erhielten die Teilnehmer:innen zusätzliche, kontextbasierte Informationen zu dem bestehenden System, beispielsweise Annahmen zu eingesetzten Technologien, Benutzerrollen oder Sicherheitsmaßnahmen. Alternativ konnten sie eigene ergänzende Beschreibungen hinzufügen. Die KI wurde erneut mit der erweiterten Beschreibung zur Durchführung einer Threat-Modeling-Analyse aufgefordert. Mit diesem Szenario sollte beobachtet werden, welchen Einfluss zusätzliche Kontextinformationen auf die Qualität, Tiefe und Nachvollziehbarkeit der Analyse haben und inwiefern der iterative Dialog zwischen Nutzer:in und KI zur Verbesserung der Ergebnisse beiträgt.

3.3.4.3. Szenario 3: „Think like a hacker“ – Angreiferperspektive In diesem dritten Szenario wurde ein explorativer Ansatz verfolgt: Die Teilnehmer:innen forderten die KI aus der Perspektive eines Angreifers („Think like a hacker“) auf, potenzielle Angriffe, Missbrauchsszenarien oder Schwachstellen zu erläutern. Dabei konnten sowohl hypothetische Angriffsideen als auch White-Hat-Hacking-Ansätze thematisiert werden. Im Anschluss sollten die identifizierten Angriffe in Bezug zu möglichen Gegenmaßnahmen und Threat-Modeling-Vorschlägen gesetzt werden. In diesem Szenario lag der Fokus auf dem Verständnis komplexer Angriffsmuster, der Erklärungstiefe der KI und dem wahrgenommenen Nutzen der Ergebnisse für sicherheitsrelevante Entscheidungsprozesse.

Während aller drei Szenarien wurde insbesondere darauf geachtet, wie die Teilnehmenden mit den Ausgaben der KI interagierten, inwieweit sie den vorgeschlagenen Ergebnissen vertrauten, wie sie mit Unsicherheiten umgingen und ob sie die KI-Vorschläge kritisch reflektierten. Die Rückmeldungen wurden qualitativ ausgewertet, indem das Nutzungsverhalten beobachtet, die Fragebogenantworten analysiert und spontane Kommentare und

Anmerkungen der Teilnehmenden berücksichtigt wurden. Ziel der Durchführung war es, die Funktionalität, Bedienbarkeit, Verständlichkeit und den wahrgenommenen Nutzen des Prototyps unter praxisnahen Bedingungen zu überprüfen.

4. Nutzerstudie Ergebnisse

Die folgenden Resultate beruhen auf den Rückmeldungen von 13 Personen, die im Rahmen einer praktischen Interface-Evaluation den KI-gestützten Prototyps getestet haben. Die Teilnehmenden arbeiteten an drei aufeinander folgenden Szenarien, in denen sie das Tool zur Analyse eines DFD, zur iterativen Kontextanreicherung und zur Untersuchung potenzieller Angriffe aus der Sicht des Angreifers verwendeten. Die Auswertung zielt darauf ab, die Wahrnehmung der Funktionalität, Interaktivität, Verständlichkeit und des Vertrauens in das System zu erfassen. Die Resultate basieren auf den Antworten aus dem Fragebogen und stellen die unmittelbaren Eindrücke der Teilnehmenden dar.

4.1. Teilnehmer:innen Hintergrund

Die Selbsteinschätzung der Vorerfahrung zeigt ein heterogenes, aber insgesamt technikaffines Teilnehmerfeld. Ein Großteil der Teilnehmenden gab an, mit Data-Flow-Diagrammen (DFDs) grundsätzlich vertraut zu sein, wobei sich die Einschätzungen über die gesamte Likert-Skala verteilten. Dies deutet darauf hin, dass sowohl Personen mit solider praktischer Erfahrung als auch Teilnehmende mit eher grundlegenden Kenntnissen vertreten waren.

Im Hinblick auf frühere Erfahrungen mit Threat Modeling oder sicherheitsbezogenen Analysen zeigte sich ein ähnliches Bild: Einige Teilnehmende verfügten bereits über einschlägige Vorerfahrung, während andere diesen Bereich bislang kaum oder gar nicht praktisch angewendet hatten. Die Stichprobe umfasste damit sowohl erfahrene als auch weniger erfahrene Nutzer:innen sicherheitsbezogener Analyseverfahren.

Deutlich ausgeprägter war hingegen die Erfahrung mit großen Sprachmodellen. Die Mehrheit der Teilnehmenden gab an, bereits Erfahrung mit Systemen wie ChatGPT oder GPT-4 zu haben, wobei insbesondere höhere Zustimmungswerte dominierten. Dies legt nahe, dass KI-basierte Assistenzsysteme für viele Teilnehmende kein völlig neues Interaktionsparadigma darstellten.

Auch das grundsätzliche Vertrauen in KI-Systeme zur Unterstützung softwarebezogener Aufgaben war überwiegend positiv ausgeprägt. Die Antworten konzentrierten sich hier vor allem auf mittlere bis hohe Zustimmungswerte, was auf eine grundsätzlich offene, aber nicht unkritische Haltung gegenüber dem Einsatz von KI in professionellen Kontexten schließen lässt.

Zusammenfassend lässt sich festhalten, dass die Teilnehmenden eine breite, realistische Mischung aus IT-naher Fachlichkeit, unterschiedlicher Erfahrung im Bereich Security sowie hoher Vertrautheit mit KI-gestützten Werkzeugen repräsentieren. Diese Zusammensetzung eignet sich besonders gut zur Untersuchung der wahrgenommenen Verständlichkeit, Transparenz und Vertrauenswürdigkeit eines KI-gestützten Threat-Modeling-Systems.

4.1.1. Szenario 1: Analyse eines gegebenen DFDs

Im ersten Szenario luden die Teilnehmenden ein vorgegebenes DFD im JSON-Format in das Tool hoch und ließen eine erste Bedrohungsanalyse nach dem STRIDE-Modell durch die KI durchführen.

Die Mehrheit der Teilnehmenden gab an, dass das System das DFD grundsätzlich korrekt interpretierte und relevante Systemkomponenten sowie Datenflüsse identifizierte. Auch die generierten Bedrohungskategorien wurden überwiegend als plausibel wahrgenommen. Abbildung 8 zeigt die Bewertungen zur Verständlichkeit der Analyse. Der Mittelwert liegt bei $M = 4,92$, bei einer Standardabweichung von $SD = 1,03$. Dies deutet darauf hin, dass die Verständlichkeit insgesamt eher positiv eingeschätzt wurde, die Bewertungen jedoch merklich streuten. Die erhöhte Standardabweichung weist darauf hin, dass die Nachvollziehbarkeit der Analyse von den Teilnehmenden unterschiedlich wahrgenommen wurde und nicht für alle gleichermaßen gegeben war.

Gleichzeitig zeigten die Antworten, dass die Verständlichkeit und Nachvollziehbarkeit der Ergebnisse unterschiedlich bewertet wurde. Während einige Teilnehmende angaben, die Ableitung der Bedrohungen gut nachvollziehen zu können, äußerten andere Unsicherheiten hinsichtlich der Begründungen und der Tiefe der Analyse. Die Vertrauensbewertungen der Teilnehmenden, welche die Akzeptanz und Zuverlässigkeit der KI-Analyse reflektieren, sind

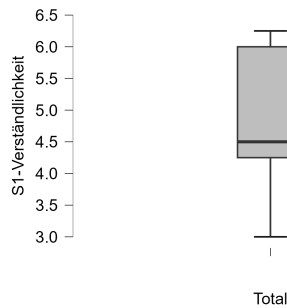


Abbildung 8: Szenario 1 – Verständlichkeit

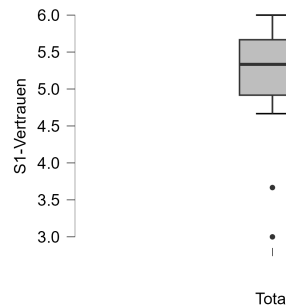


Abbildung 9: Szenario 1 – Vertrauen

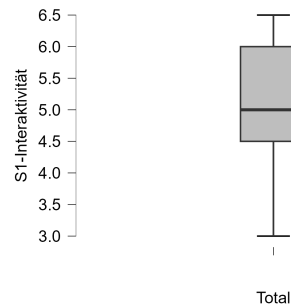


Abbildung 10: Szenario 1 – Interaktivität

in Abbildung 9 visualisiert. Die kompakte Lage des zentralen Bereichs weist auf eine überwiegend positive Einschätzung hin, während einzelne niedrigere Bewertungen auf verbleibende Vorbehalte einzelner Teilnehmender schließen lassen. Die Kombination aus Mittelwert ($M = 5,06$) und der Standardabweichung ($SD = 0,91$) erlaubt eine differenzierte Betrachtung des wahrgenommenen Vertrauens und verdeutlicht, dass Vertrauen zwar mehrheitlich vorhanden war, jedoch nicht einheitlich ausgeprägt. Das Vertrauen war tendenziell höher, wenn die KI explizit auf Annahmen oder fehlenden Kontext hinwies.

Mehrere Teilnehmer:innen wiesen außerdem darauf hin, dass Unsicherheiten oder Annahmen des Systems nicht immer eindeutig gekennzeichnet wurden. Die Abbildung 10 stellt die Bewertungen zur Interaktivität dar. Die positive durchschnittliche Bewertung ($M = 5,08$) spricht für eine grundsätzlich als hilfreich empfundene Interaktion, während die vergleichsweise höhere Streuung ($SD = 1,15$) darauf hindeutet, dass die wahrgenommene

Qualität der Dialogführung zwischen den Teilnehmenden variierte. Einige Teilnehmer:innen gaben an, dass sie sich stärker geführt gefühlt hätten, wenn das System proaktiver auf Informationslücken hingewiesen hätte. Die Visualisierung zeigt somit, dass die Interaktivität zwar gegeben ist, aber noch Raum für Optimierungen besteht, insbesondere hinsichtlich der Unterstützung bei der Kontextaufnahme.

Insgesamt lässt sich festhalten, dass das Tool im ersten Szenario eine solide Grundlage für die Bedrohungsanalyse bietet. Die Teilnehmenden konnten die Ergebnisse im Großen und Ganzen nachvollziehen und bewerteten die Interaktion als hilfreich. Gleichzeitig zeigen die Abbildungen 8–10 die Unterschiede in der individuellen Wahrnehmung, insbesondere was die Nachvollziehbarkeit der Ableitungen, die Kommunikation von Unsicherheiten und die proaktive Interaktion betrifft. Diese Details liefern wertvolle Hinweise dazu, welche Aspekte der Benutzerführung und Transparenz in zukünftigen Versionen des Systems weiter optimiert werden sollten.

4.1.2. Szenario 2: Iterative Verbesserung durch zusätzlichen Kontext

In einem zweiten Szenario erweiterten die Teilnehmenden das bestehende DFD um kontextbasierte Zusatzinformationen, beispielsweise zur Verschlüsselung der Datenbank, zu den verwendeten Authentifizierungsverfahren oder zur öffentlichen Zugänglichkeit bestimmter Schnittstellen. Das Ziel bestand darin, zu prüfen, wie das System auf genauere Eingaben reagiert und ob sich dadurch die Qualität der Bedrohungsanalyse verbessert.

Den Ergebnissen zufolge nahm die Mehrheit der Teilnehmenden eine spürbare Veränderung der Analyse wahr, sobald zusätzliche Informationen bereitgestellt wurden. Viele äußerten, dass die Bedrohungsszenarien konkreter wurden und intensiver auf die beschriebenen Sicherheitsmechanismen eingingen. Abbildung 11 stellt die Bewertungen zur Verständlichkeit in Szenario 2 dar. Die vergleichsweise höhere Lage des Medians sowie eine geringere Streuung ($SD = 1,04$) im Vergleich zu Szenario 1 deuten darauf hin, dass die zusätzliche Kontextinformation zu konsistenteren und nachvollziehbareren Bewertungen führte. Der eingezeichnete Mittelwert ($M = 5,56$) unterstützt diese Beobachtung und unterstreicht den positiven Einfluss

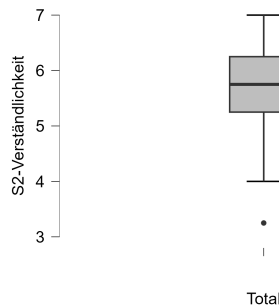


Abbildung 11: Szenario 2 – Verständlichkeit

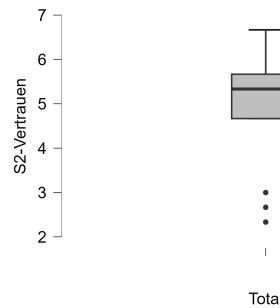


Abbildung 12: Szenario 2 – Vertrauen

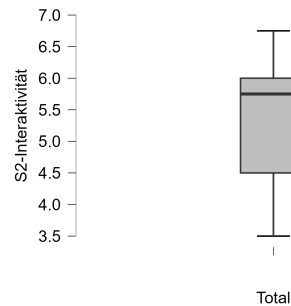


Abbildung 13: Szenario 2 – Interaktivität

der Kontextanreicherung auf die wahrgenommene Analysequalität. Auch die Nachvollziehbarkeit der Begründungen wurde von vielen Teilnehmenden positiv bewertet, wobei einzelne niedrigere Werte auf verbleibende Unsicherheiten hinweisen. Diese Darstellung zeigt, dass die zusätzlichen Informationen die Analyse für die Nutzer:innen verständlicher und strukturierter machten.

Die Vertrauensbewertungen in Abbildung 12 weisen einen Mittelwert von $M = 4,87$ bei einer Standardabweichung von $SD = 1,35$ auf. Dies zeigt ein insgesamt positives, jedoch weniger einheitliches Vertrauensbild. Die erhöhte Streuung deutet darauf hin, dass zusätzliche Informationen zwar das durchschnittliche Vertrauen unterstützten, jedoch nicht bei allen Teilnehmenden gleichermaßen zur Reduktion von Unsicherheiten beitrugen. Besonders deutlich wird, dass der Umgang des Systems mit Unsicherheiten als angemessen bewertet wurde, wobei einzelne niedrigere Bewertungen auf verbleibende Bedenken hindeuten. Die Ergebnisse verdeutlichen, dass

zusätzlicher Kontext einen positiven Einfluss auf die wahrgenommene Qualität der Analyse hat. Die Unterstützung bei der Erhebung dieses Kontexts ist aus Sicht der Teilnehmenden jedoch noch ausbaufähig.

Abbildung 13 visualisiert die Bewertungen zur Interaktivität mithilfe eines Boxplots. Die Verteilung der Werte und einem Mittelwert von $M = 5,42$ zeigt, dass das System überwiegend als reaktionsfähig wahrgenommen wurde, zugleich jedoch Unterschiede hinsichtlich der erwarteten Proaktivität des Dialogs bestehen. Die Streuung ($SD = 1,03$) deutet darauf hin, dass die Interaktionslogik nicht in allen Fällen den Erwartungen der Nutzenden entsprach. Die Rückfragen des Systems wurden überwiegend als unterstützend wahrgenommen, wobei die Bewertungen hinsichtlich der Dialogführung variierten. Einige Teilnehmende wünschten sich eine stärkere proaktive Rolle des Tools, etwa Hinweise auf fehlende Kontextinformationen. Die Abbildung macht deutlich, dass die Interaktion angenehm war, aber noch Verbesserungspotenzial besteht, um das System dialogischer und nutzerzentrierter zu gestalten. Die Antworten zeigten, dass das System nicht in allen Fällen aktiv nach fehlenden Informationen fragte. Einige Teilnehmende berichteten, dass sie selbst entscheiden mussten, welche Details relevant sein könnten, da das Tool nur eingeschränkt Hinweise auf Informationslücken gab. Zwar reagierte das System auf neue Eingaben, übernahm jedoch nur teilweise eine aktive, dialogführende Rolle.

Insgesamt zeigt das zweite Szenario, dass zusätzliche Kontextinformationen die Analyse deutlich verbessern. Die Teilnehmenden bewerteten die Bedrohungen als konkreter, die Ergebnisse als nachvollziehbarer und ihr Vertrauen in die Analyse stieg. Die Abbildungen 11–13 verdeutlichen jedoch, dass die Interaktivität und die proaktive Unterstützung des Systems unterschiedlich wahrgenommen wurden. Dies weist darauf hin, dass die Benutzerführung, die Dialogsteuerung und die Hinweise auf fehlenden Kontext in künftigen Versionen gezielt optimiert werden sollten.

4.1.3. Szenario 3: „Think like a hacker“ – Angriffsdenken und Vertrauensbewertung

In dem dritten Szenario sollten die Teilnehmenden gemeinsam mit der KI potenzielle Angriffe aus der Sicht eines Angreifers analysieren. Dabei sollten Bedrohungen näher untersucht, Angriffsvektoren erläutert und potenzielle Gegenmaßnahmen im Sinne des "White-Hat-Hacking" Ansatzes erörtert werden.

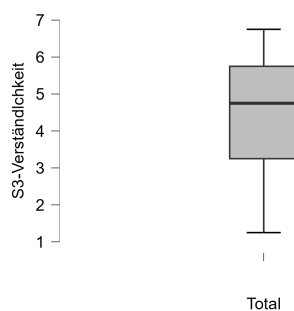


Abbildung 14: Szenario 3 – Verständlichkeit

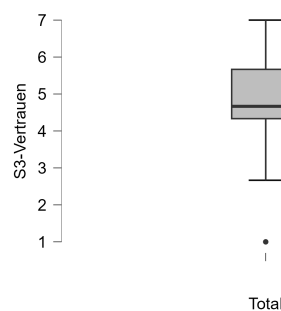


Abbildung 15: Szenario 3 – Vertrauen

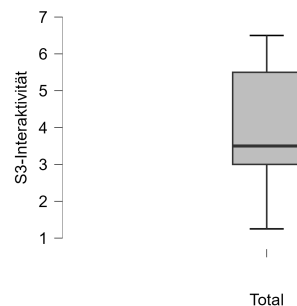


Abbildung 16: Szenario 3 – Interaktivität

Die Rückmeldungen verdeutlichen, dass dieses Szenario von zahlreichen Teilnehmenden als besonders interessant und lehrreich angesehen wurde. Mehrere äußerten, dass ihnen die KI dabei half, Angriffe besser zu verstehen und neue Einsichten in potenzielle Schwachstellen zu gewinnen. Abbildung 14 zeigt die Bewertungen zur Verständlichkeit. Im Vergleich zu den vorherigen Szenarien ist eine größere Streuung erkennbar, was auf unterschiedliche Wahrnehmungen der Erklärungen und der inhaltlichen Tiefe hinweist. Der Mittelwert liegt bei $M = 4,37$, bei einer Standardabweichung

von $SD = 1,72$. Dies deutet auf eine insgesamt nur mittlere Verständlichkeit hin, wobei die hohe Streuung auf stark unterschiedliche Einschätzungen der Teilnehmenden hinsichtlich Tiefe und Klarheit der Erklärungen schließen lässt. Die Diagramme zeigen, dass die Teilnehmenden die Erklärungen überwiegend nachvollziehbar fanden, insbesondere die Darstellung von Angriffsszenarien und deren Zusammenhang mit dem DFD. Gleichzeitig wird sichtbar, dass die Grenzen der Analyse noch nicht immer klar erkannt wurden, was durch einzelne niedrigere Werte unterstrichen wird.

Die Darstellung der Vertrauensbewertungen in Abbildung 15 verdeutlicht ein heterogenes Meinungsbild mit einem Mittelwert von $M = 4,56$ und eine Standardabweichung von $SD = 1,64$. Während ein Teil der Bewertungen im oberen Skalenbereich liegt, zeigen einzelne niedrigere Werte, dass insbesondere bei komplexeren Angriffsszenarien Unsicherheiten bestanden. Die Analyse wurde als glaubwürdiger angesehen, wenn die KI eigene Unsicherheiten zum Ausdruck brachte oder auf fehlenden Kontext aufmerksam machte. Fehlende Transparenz oder allgemeine Aussagen hatten hingegen negative Auswirkungen auf das Vertrauen.

Abbildung 16 zeigt, dass die Teilnehmenden die Unterstützung durch Rückfragen und die dialogische Interaktion überwiegend als hilfreich empfanden. Einige Teilnehmende äußerten Bedenken hinsichtlich der inhaltlichen Tiefe sowie der sicherheitsbedingten Einschränkungen der KI. Insbesondere bei der Thematisierung detaillierterer Angriffsszenarien wurden einige Antworten als zu allgemein oder ausweichend bewertet. Dies führte bei einigen Teilnehmenden zu Verunsicherungen bezüglich der Vollständigkeit der Analyse.

Insgesamt verdeutlicht das dritte Szenario, dass das Tool die Analyse aus Angreifersicht sinnvoll unterstützt und die Verständlichkeit der Angriffsszenarien überwiegend positiv bewertet wurde. Die Abbildungen 14–16 zeigen jedoch, dass die Erkennung von Analysegrenzen und die proaktive Interaktion noch verbesserungswürdig sind. Diese Erkenntnisse geben wertvolle Hinweise für die Optimierung von Benutzerführung, Transparenz und Vertrauenskommunikation in zukünftigen Versionen.

4.1.4. Zusammenfassende Ergebnisdarstellung

Die Bewertungen deuten auf eine insgesamt positive Grundhaltung gegenüber dem Prototyp hin. Gleichzeitig machen vereinzelte niedrigere Bewertungen deutlich, dass trotz der grundsätzlichen Akzeptanz weiterhin Unsicherheiten und Optimierungsbedarfe bestehen. Die positiven Bewertungen zur generellen Interaktion und dem Vertrauen verdeutlichen die Akzeptanz des Systems, während einzelne niedrigere Werte auf bestehende Unsicherheiten und Wünsche nach mehr Transparenz und Proaktivität hinweisen.

Die Ergebnisse aller drei Szenarien verdeutlichen, dass das KI-gestützte Interface als funktionaler Prototyp angesehen wird, der bei grundlegenden Threat-Modeling-Aufgaben Unterstützung bietet. Insbesondere die Möglichkeit, die Analyse schrittweise zu verfeinern, und die Hilfestellung beim Verständnis von Angriffsszenarien wurden von den Teilnehmenden positiv bewertet.

Zugleich machen die Antworten deutlich, dass die Qualität der Ergebnisse stark von der Quantität und Struktur der bereitgestellten Informationen abhängt. Das System wird als interaktiv beschrieben, jedoch nicht immer als ausreichend. Außerdem wird deutlich, dass Transparenz, Nachvollziehbarkeit und die explizite Mitteilung von Unsicherheiten entscheidend für das Vertrauen der Nutzenden sind.

Das zusammenfassende Feedback bestätigt die generelle Nützlichkeit und Akzeptanz des Systems, weist jedoch zugleich auf Verbesserungspotenzial in den Bereichen Transparenz, proaktive Hinweise, Nachvollziehbarkeit und Interaktivität hin. Diese Erkenntnisse liefern eine fundierte Grundlage für die weitere Optimierung des Systems und die gezielte Verbesserung von Benutzerführung, Vertrauenskommunikation und Analysequalität.

5. Diskussion

Das Ziel dieser Arbeit bestand darin, zu untersuchen, inwiefern ein KI-gestützter Assistent Nutzer:innen beim Threat Modeling unterstützen kann und welche Auswirkungen dies auf die Nachvollziehbarkeit, das Vertrauen und die Interaktivität hat. Die Ergebnisse der praktischen Studie werden im Folgenden vor dem Hintergrund bestehender Forschung diskutiert und anhand der aufgestellten Hypothesen (H1, H2, H3) eingeordnet.

5.1. Verständlichkeit und Transparenz einer KI (H1)

Die Studie bestätigt die in Hypothese H1 getroffene Annahme, dass die Qualität und Struktur der Eingaben wesentlichen Einfluss auf die Nachvollziehbarkeit und Brauchbarkeit der von KI generierten Threat-Modeling-Ergebnisse haben. Vor allem im ersten Szenario, in dem nur ein DFD ohne zusätzlichen Kontext verwendet wurde, bezeichneten viele Teilnehmende die Analyse als zu oberflächlich oder zu generisch. Im zweiten Szenario, in dem der Kontext zunehmend angereichert wurde, wurden die Ausgaben dagegen als differenzierter, relevanter und nachvollziehbarer wahrgenommen.

Diese Beobachtungen stimmen mit den Ergebnissen von Yang et al. [Wu et al., 2024] überein, die zeigen, dass LLMs zwar Bedrohungen automatisch identifizieren und STRIDE-Kategorien zuordnen können, die Qualität der Analyse jedoch stark von der Qualität der Eingangsdaten abhängt. Auch Mollaeefar et al. [Mollaeefar et al., 2024] heben hervor, dass ein begrenztes Verständnis des Kontexts durch die Modelle zu unvollständigen oder unangemessenen Sicherheitsempfehlungen führen kann. Die Studie bestätigt die Einschränkung auf der Interface-Ebene und macht deutlich, dass strukturierte Eingangsdaten eine wesentliche Voraussetzung für den sinnvollen Einsatz von LLMs im Threat Modeling sind.

Außerdem unterstützen die Ergebnisse die Forderung nach iterativen Analyseprozessen, wie sie auch von Chis et al. [a) Chiş et al., 2024] vorgeschlagen werden. DFDs allein bilden Sicherheitsmaßnahmen oft nicht ausreichend

ab, weshalb ergänzende Informationen erforderlich sind, um realistische Bedrohungsszenarien abzuleiten.

5.2. Vertrauen in den KI-Assistenten (H2)

Die Hypothese H2 ging davon aus, dass das Vertrauen der Nutzer:innen in die KI wächst, wenn Unsicherheiten offen angesprochen werden und eine menschliche Kontrolle der Ergebnisse gewährleistet ist. Die Ergebnisse der Studie legen jedoch nahe, dass Vertrauen nicht automatisch durch die bloße Bereitstellung von KI-generierten Analysen entsteht. Vielmehr hängt es wesentlich von der Verständlichkeit, Begründungstiefe und Offenlegung von Annahmen ab.

Mehrere Teilnehmende zeigten sich skeptisch gegenüber Aussagen der KI, die endgültig wirkten oder nicht weiter erklärt wurden. Zugleich wurde lobend angemerkt, wenn die KI Einschränkungen deutlich machte oder direkt zu einer kritischen Überprüfung der Ergebnisse einlud. Dieses Ergebnis deckt sich mit den Ergebnissen von Mollaeefar et al. (2024) [Mollaeefar et al., 2024], die die eingeschränkte Nachvollziehbarkeit von LLM-Entscheidungen als zentrales Problem identifizieren. Mbaka und Tuma [Mbaka and Tuma, 2024] demonstrieren ebenfalls, dass vor allem Nutzer:innen mit geringer Erfahrung dazu tendieren, KI-Empfehlungen ohne kritische Prüfung anzunehmen. Dies unterstreicht die Notwendigkeit von Transparenz und nachvollziehbaren Entscheidungen.

Laut der vorliegenden Untersuchung sollte ein Interface, das Offenheit statt Autorität ausstrahlt, Vertrauen schaffen. Als zentraler Aspekt eines verantwortungsvollen KI-gestützten Threat-Modeling-Prozesses wird angesehen, dass Ergebnisse hinterfragt, korrigiert oder weiterentwickelt werden können.

5.3. Interaktivität und iterative Nutzung (H3)

Die Ergebnisse unterstützen Hypothese H3, nach der ein Interface Offenheit nutzen sollte, um Vertrauen zu schaffen. Insbesondere in den Szenarien zwei und drei zeigte sich, dass die Teilnehmenden den iterativen Charakter

der Analyse als hilfreich empfanden, um eigene Annahmen zu reflektieren, zusätzliche Informationen einzubringen und alternative Perspektiven einzunehmen.

Dieser Befund deckt sich mit den Erkenntnissen von Sahoo et al. [Sahoo et al., 2024], die zeigen, dass sich die Qualität von LLM-Ausgaben bei komplexen Aufgaben durch gezieltes Prompt Engineering und iterative Techniken wie „Chain of Thought“ oder „Self-Refine“ erheblich verbessern lässt. Die im dritten Szenario verwendete Angreiferperspektive („Think like a hacker“) ermöglichte es den Teilnehmenden zudem, Bedrohungen aus einem erweiterten Blickwinkel zu betrachten und potenzielle Angriffspfade besser zu verstehen.

Gleichzeitig wurde deutlich, dass eine zu starke Automatisierung kritisch gesehen wird. Diese Einschätzung steht im Einklang mit früheren Arbeiten zu manuellen und halbautomatisierten Threat-Modeling-Ansätzen, die die Notwendigkeit menschlicher Expertise betonen [Scandariato et al., 2015], [Singh et al., 2019]. Die Ergebnisse sprechen daher für ein hybrides Modell, bei dem die KI als Assistenzsystem fungiert, jedoch nicht als alleinige Entscheidungsinstanz.

5.4. Zusammenfassende Einordnung

Zusammenfassend bestätigen die Ergebnisse dieser Untersuchung wesentliche Erkenntnisse der aktuellen Forschung: Obwohl Large Language Models (LLMs) ein großes Potenzial zur Unterstützung des Threat Modelings haben, sind sie stark von gut strukturierten Eingaben, transparenten Ausgaben und einer aktiven Rolle des Menschen im Analyseprozess abhängig. Diese Studie baut auf bestehenden Arbeiten auf, indem sie diese Aspekte nicht nur auf Modell- oder Tool-Ebene, sondern konkret im Rahmen einer nutzerzentrierten Oberfläche untersucht.

Die Ergebnisse unterstreichen somit die Auffassung, dass KI-gestützte Threat-Modeling-Tools vor allem dann sinnvoll sind, wenn sie als dialogische, erklärende und adaptive Systeme gestaltet sind. Für eine effektive und verantwortungsvolle Sicherheitsanalyse ist die Zusammenarbeit von Mensch und Maschine weiterhin entscheidend.

5.5. Limitation der Studie

Trotz der gewonnenen Erkenntnisse weist die vorliegende Arbeit mehrere Einschränkungen auf, die bei der Einordnung der Ergebnisse berücksichtigt werden müssen.

Eine zentrale Limitation betrifft die geringe Stichprobengröße. An der Nutzerstudie nahmen insgesamt 13 Personen teil, wodurch die Ergebnisse vor allem als explorativ zu verstehen sind. Ursprünglich war eine größere Anzahl an Teilnehmenden vorgesehen, jedoch kam es im Rekrutierungsprozess zu zahlreichen Absagen. Gründe hierfür waren unter anderem fehlende zeitliche Ressourcen, geringes Interesse an KI-gestützten Systemen oder eine grundsätzliche Zurückhaltung gegenüber Studien, die eine aktive Teilnahme in Form von Online-Meetings (Zoom) erforderten. Auch Anfragen in Online-Foren und fachbezogenen Communities führten nur zu einer begrenzten Resonanz. Eine breitere und diversere Stichprobe hätte eine stärkere Generalisierbarkeit der Ergebnisse ermöglicht.

Darüber hinaus konnte keine statistisch belastbare quantitative Auswertung vorgenommen werden. Aufgrund der explorativen Ausrichtung der Studie und der geringen Teilnehmerzahl lag der Fokus auf qualitativen Rückmeldungen, Beobachtungen und subjektiven Einschätzungen der Nutzenden. Ein weiterführender Vergleich, etwa zwischen verschiedenen Nutzergruppen oder alternativen Tool-Konzepten, war im Rahmen dieser Arbeit nicht möglich, stellt jedoch einen wichtigen Ansatzpunkt für zukünftige Untersuchungen dar.

Eine weitere Einschränkung ergibt sich aus dem Funktionsumfang des entwickelten Prototyps. Der Prototyp wurde bewusst als Minimalversion konzipiert, um zentrale Interaktions- und Nutzungskonzepte zu testen. Im Verlauf des Pilot-Tests und der Evaluation wurden jedoch zahlreiche Erweiterungswünsche geäußert, die aus zeitlichen und technischen Gründen nicht umgesetzt werden konnten. Dazu zählen insbesondere grafische Visualisierungen von Bedrohungen, interaktive DFD-Editoren, weiterführende Diagramme sowie eine stärkere visuelle Aufbereitung der Analyseergebnisse. Diese fehlenden Funktionen könnten die Verständlichkeit und Nutzbarkeit des Systems in einem produktiven Einsatz weiter erhöhen.

Zudem wurde der Prototyp ausschließlich in einem kontrollierten Testszenario evaluiert. Die Nutzung in realen Entwicklungsprojekten über längere Zeiträume hinweg konnte nicht untersucht werden. Aussagen zur langfristigen Akzeptanz, zur Integration in bestehende Entwicklungsprozesse oder zum tatsächlichen Einfluss auf die Qualität von Sicherheitsentscheidungen sind daher nur eingeschränkt möglich.

Abschließend ist zu beachten, dass die Studie sich auf ein spezifisches LLM und ein klar umrissenes Anwendungsszenario konzentriert. Die Ergebnisse lassen sich daher nicht ohne Weiteres auf andere Modelle, Architekturen oder Organisationskontexte übertragen.

6. Fazit und künftige Arbeiten

Das Ziel dieser Bachelorarbeit war es, zu untersuchen, inwiefern sich LLMs, am Beispiel von ChatGPT, als unterstützende Werkzeuge im Threat-Modeling-Prozess einsetzen lassen. Der Fokus lag dabei auf der Konzeption eines Prototyps und dessen empirischer Evaluation. Dabei handelt es sich um ein KI-gestütztes Interface, das DFDs nutzt und etablierte Frameworks wie STRIDE integriert. Im Rahmen eines iterativen Vorgehens wurde zunächst ein konzeptioneller Prototyp entwickelt und in einem Experten-Workshop diskutiert. Anschließend erfolgte die Evaluation in einer praktischen Studie mit Teilnehmenden aus der Softwareentwicklung.

Die Ergebnisse der empirischen Untersuchung zeigen, dass KI-gestützte Ansätze im Threat Modeling grundsätzlich als hilfreich wahrgenommen werden, insbesondere bei der strukturierten Identifikation potenzieller Bedrohungen und der Unterstützung beim Verständnis sicherheitsrelevanter Zusammenhänge. Insbesondere Szenarien, in denen zusätzlicher Kontext bereitgestellt oder ein dialogbasierter Ansatz verfolgt wurde, führten zu nachvollziehbareren und qualitativ besser bewerteten Ergebnissen. Damit bestätigt die Arbeit, dass LLMs ihr Potenzial vor allem dann entfalten, wenn sie nicht isoliert, sondern als interaktive Assistenzsysteme eingesetzt werden.

Gleichzeitig wurden jedoch auch die klaren Grenzen des Ansatzes deutlich. So zeigt die Studie beispielsweise, dass die Qualität der generierten Bedrohungsanalysen stark von der Struktur und Vollständigkeit der Eingaben abhängt. Unzureichend beschriebene oder stark abstrahierte DFDs führten zu oberflächlichen oder teilweise irreführenden Ergebnissen. Zudem schätzten die Teilnehmenden das Vertrauen in die KI-Ausgaben überwiegend als moderat ein. Dies unterstreicht die Notwendigkeit menschlicher Kontrolle und fachlicher Einordnung. Die KI wurde nicht als Ersatz, sondern als unterstützendes Werkzeug wahrgenommen, das insbesondere weniger erfahrene Nutzer:innen anleiten kann. Eine vollautomatische Bedrohungsbewertung sollte jedoch nicht von der KI übernommen werden.

Insgesamt lässt sich festhalten, dass KI-gestütztes Threat Modeling ein vielversprechender Ansatz ist, der insbesondere zur Effizienzsteigerung, zur Unterstützung von Lernprozessen und zur Strukturierung komplexer Sicherheitsanalysen beitragen kann. Die Arbeit bestätigt zugleich die in der Literatur beschriebenen Herausforderungen in Bezug auf das Kontextverständnis, die Erklärbarkeit und das Risiko eines unkritischen Vertrauens in KI-generierte Ergebnisse. Damit fügt sich diese Untersuchung in den aktuellen Forschungsstand ein und liefert zusätzliche empirische Erkenntnisse aus einer nutzerzentrierten Perspektive.

Aufbauend auf den Ergebnissen dieser Arbeit ergeben sich mehrere Ansatzpunkte für zukünftige Forschung und Weiterentwicklung. Ein zentraler Aspekt betrifft die Optimierung der Eingabestruktur. Zukünftige Arbeiten könnten untersuchen, wie sich DFDs durch zusätzliche Metadaten oder semantische Anreicherungen ergänzen lassen, um der KI ein besseres Kontextverständnis zu ermöglichen. Dabei wären hybride Modellierungsansätze denkbar, die klassische DFDs mit maschinenlesbaren Repräsentationen kombinieren.

Darüber hinaus bietet sich eine weiterführende Evaluation mit einer größeren und heterogeneren Stichprobe an, um Unterschiede zwischen Expert:innen und weniger erfahrenen Nutzer:innen systematischer zu analysieren. Insbesondere das Vertrauen in KI-gestützte Sicherheitsanalysen sowie der Umgang mit falsch-positiven oder unvollständigen Ergebnissen sind hierbei relevante Forschungsfragen.

Ein weiterer zukünftiger Schwerpunkt liegt in der Erweiterung des Prototyps um zusätzliche Funktionen. Denkbar wären die Integration weiterer Frameworks wie MITRE ATT&CK oder PASTA, eine explizite Priorisierung von Bedrohungen sowie erklärbare KI-Mechanismen, um die Ergebnisse besser nachvollziehen zu können. Auch die Einbindung von Prompt-Engineering-Strategien oder adaptiven Dialogmechanismen könnte die Qualität der Analyseergebnisse weiter verbessern.

Abschließend bietet diese Arbeit eine Grundlage für weiterführende Untersuchungen zur Rolle von KI als interaktive Assistenz im Bereich der IT-Sicherheit. Insbesondere im Sinne eines Human-in-the-Loop-Ansatzes besteht großes Potenzial, KI-Systeme so zu gestalten, dass sie menschliche Expertise sinnvoll ergänzen, ohne kritische Entscheidungen vollständig zu automatisieren.

Literatur

- [a) Chiş et al., 2024] a) Chiş, A., Stoica, O. I., Ghiran, A.-M., and Buchmann, R. A. (2024). A knowledge graph approach to cyber threat mitigation derived from data flow diagrams. In *2024 IEEE International Conference on Automation, Quality and Testing, Robotics (AQTR)*, pages 1–6. IEEE.
- [b) Chiş et al., 2024] b) Chiş, A., Stoica, O. I., and Ghiran, A.-M. (2024). A modeling approach to cyber threat mitigation.
- [DeMarco, 2011] DeMarco, T. (2011). Structured analysis and system specification. In *Software pioneers: contributions to software engineering*, pages 529–560. Springer.
- [Horst, 2025] Horst, P. (2025). Das datenflussdiagramm — einfaches beispiel: Hotelbuchung. https://www.peterjohann-consulting.de/datenflussdiagramm/?utm_source.
- [Mbaka and Tuma, 2024] Mbaka, W. B. and Tuma, K. (2024). Usefulness of data flow diagrams and large language models for security threat validation: a registered report. *arXiv preprint arXiv:2408.07537*.
- [Mollaeefar et al., 2024] Mollaeefar, M., Bissoli, A., and Ranise, S. (2024). Pillar: an ai-powered privacy threat modeling tool. *arXiv preprint arXiv:2410.08755*.
- [Sahoo et al., 2024] Sahoo, P., Singh, A. K., Saha, S., Jain, V., Mondal, S., and Chadha, A. (2024). A systematic survey of prompt engineering in large language models: Techniques and applications. *arXiv preprint arXiv:2402.07927*.
- [Scandariato et al., 2015] Scandariato, R., Wuyts, K., and Joosen, W. (2015). A descriptive study of microsoft’s threat modeling technique. *Requirements Engineering*, 20:163–180.
- [Sharma and Bhushan, 2026] Sharma, A. and Bhushan, K. (2026). A comprehensive survey on iot security: Challenges, security issues, and countermeasures. *Computer Science Review*, 59:100839.

- [Shostack, 2014] Shostack, A. (2014). *Threat modeling: Designing for security*. John Wiley & Sons.
- [Singh et al., 2019] Singh, K., Saal, M., and Sakalas, A. (2019). Towards automating a risk-first threat analysis technique.
- [Sonnenburg et al., 2025] Sonnenburg, A., Richter, A., and Voß, S. (2025). It-sicherheit in der digitalisierten arbeitswelt: Herausforderungen, gesetzliche rahmenbedingungen und auswirkungen auf den arbeitsschutz. *Zeitschrift für Arbeitswissenschaft*, 79(3):433–450.
- [Souppaya and Scarfone, 2016] Souppaya, M. and Scarfone, K. (2016). Guide to data-centric system threat modeling. Technical report, National Institute of Standards and Technology.
- [Tuma and Mbaka, 2022] Tuma, K. and Mbaka, W. (2022). Human aspect of threat analysis: A replication. *arXiv preprint arXiv:2208.01512*.
- [Wu et al., 2024] Wu, T., Yang, S., Liu, S., Nguyen, D., Jang, S., and Abuadbba, A. (2024). Threatmodeling-llm: Automating threat modeling using large language models for banking system. *arXiv preprint arXiv:2411.17058*.
- [Xiong and Lagerström, 2019] Xiong, W. and Lagerström, R. (2019). Threat modeling—a systematic literature review. *Computers & security*, 84:53–69.

A. KI-basierte Anwendungen

Die in den Ergebnissen dargestellten Abbildungen 8 bis 17 wurden mithilfe von ChatGPT und Jasp erstellt. Zur Strukturierung und Aufbereitung der erhobenen Daten kam ChatGPT zum Einsatz, zur grafischen Darstellung der Ergebnisse wurde Matplotlib verwendet.